

PHÂN TÍCH & THIẾT KẾ HỆ THỐNG THÔNG TIN

Đề tài: Xây dựng Mạng xã hội (mô hình Facebook)

Trường thông tin	Nội dung
Tên dự án / hệ thống	Mạng xã hội — nền tảng kết nối, chia sẻ nội dung và nhắn tin (Facebook-like)
Nhóm thực hiện	Nhóm 4 — Nguyễn Gia Bách (MSSV: [NHẬP]), Hoàng Lâm (MSSV: [NHẬP]), Nguyễn Cao Kỳ (MSSV: [NHẬP])
Lớp / Học phần	[NHẬP lớp] · 30INF067 — Lập trình Web nâng cao
Backend / CSDL	ASP.NET Core 8 · PostgreSQL 16
Xác thực / phân quyền	JWT · RBAC + kiểm tra ownership
Hạ tầng	OCI (Ampere A1) + Docker, Cloudflare, chạy thật trên Internet
Phiên bản tài liệu	v5.0
Ngày cập nhật	02/09/2026
Trạng thái	Hoàn thiện (Ready)
Tên file nộp	TenLop_Nhom4_MangXaHoi.docx

1. Bối cảnh, mục tiêu và phạm vi

1.1 Tóm tắt điều hành

Vấn đề cần giải quyết. Người dùng cần một nơi để kết nối bạn bè, chia sẻ nội dung (văn bản + ảnh) và nhắn tin riêng tư theo thời gian thực, với quyền riêng tư rõ ràng và an toàn dữ liệu cá nhân. Đồ án xây dựng một mạng xã hội quy mô nhỏ theo mô hình Facebook, **triển khai thật lên Internet** ở cuối kỳ chứ không chỉ chạy trên máy cá nhân.

Giá trị kỳ vọng. Người dùng đăng bài và lướt News Feed mượt (p95 ≤ 500 ms ở 1.000 người dùng đồng thời), nhắn tin realtime độ trễ ≤ 1 giây, và mọi tài nguyên riêng tư được bảo vệ đúng theo chủ sở hữu (không có lỗ hổng IDOR).

Giải pháp ở mức khái niệm. Một **modular monolith** trên ASP.NET Core 8 + PostgreSQL 16, xác thực JWT ngắn hạn + refresh token xoay vòng, phân quyền RBAC kết hợp kiểm tra quyền sở hữu ở tầng nghiệp vụ, realtime bằng SignalR, ảnh lưu ở object storage (không lưu trong CSDL). Toàn bộ đóng gói Docker, chạy trên VPS OCI sau Cloudflare.

1.2 Mục tiêu và chỉ số thành công

ID	Mục tiêu	Chỉ số / Baseline	Target
GOAL-01	News Feed phản hồi nhanh dưới tải	p95 latency @ 1.000 CCU	p95 ≤ 500 ms
GOAL-02	Nhắn tin realtime tức thời	Độ trễ gửi→nhận	≤ 1 giây
GOAL-03	An toàn tài nguyên người dùng	Số lỗ hổng IDOR / test truy cập chéo	0 lỗ hổng
GOAL-04	Chạy thật, ổn định trên Internet	Uptime / tháng	≥ 99%
GOAL-05	Bảo vệ dữ liệu cá nhân (NĐ 13/2023)	Quyền xóa tài khoản + ẩn danh PII	Có, kiểm chứng được

1.3 Phạm vi

In scope (MVP)	Out of scope (kỳ này)	Giả định	Ràng buộc
Đăng ký/dăng nhập, xác minh email, hồ sơ	Chặn người dùng (thay bằng BR-09)	Người dùng có email hợp lệ để xác minh	Backend ASP.NET Core 8; DB PostgreSQL 16
Đăng bài (văn bản + ≤10 ảnh), quyền riêng tư	Đa ngôn ngữ (i18n)	Hạ tầng VPS có Docker (OCI Ampere A1)	Xác thực JWT; phân quyền RBAC
Bình luận 3 cấp, thả cảm xúc	Nhóm/trang, chia sẻ lại bài	Ảnh ≤ 10MB/ảnh, ≤ 10 ảnh/bài	Thời gian: ~25 ngày; đội 3 người
Kết bạn/hủy kết bạn, theo dõi	Gọi thoại/video, chat nhóm	Giao diện tiếng Việt	Công cụ: Postman, DBeaver, draw.io, Figma

In scope (MVP)	Out of scope (kỳ này)	Giả định	Ràng buộc
Nhắn tin 1-1 realtime, trạng thái đã xem	Email digest, ứng dụng di động		
News Feed, trang cá nhân, tìm kiếm người dùng			
Thông báo trong ứng dụng; báo cáo & kiểm duyệt			

1.4 Bên liên quan

Lưu ý: “Bên liên quan” (stakeholder) dùng tiền tố **STK-** để phân biệt với **actor** hệ thống (ACT-) ở Mục 2. Một số stakeholder ánh xạ tới actor: STK-01 ↔ ACT-U/ACT-G, STK-02 ↔ ACT-A, STK-03 ↔ ACT-M.

ID	Bên liên quan	Mục tiêu / mối quan tâm	Quyền quyết định	Kênh tham gia
STK-01	Người dùng cuối (End User)	Kết nối, chia sẻ, nhắn tin an toàn, dễ dùng	Inform	Review / trải nghiệm
STK-02	Quản trị viên (Admin)	Quản lý người dùng, giám sát vận hành	Consult	Review
STK-03	Kiểm duyệt viên (Moderator)	Xử lý báo cáo, gỡ nội dung xấu nhanh	Inform	Review
STK-04	Nhóm phát triển	Yêu cầu rõ, kiến trúc khả thi	Approve	Workshop
STK-05	Giảng viên hướng dẫn	Đúng phạm vi, đủ tiêu chí rubric	Approve	Review gate

1.5 Thuật ngữ nghiệp vụ

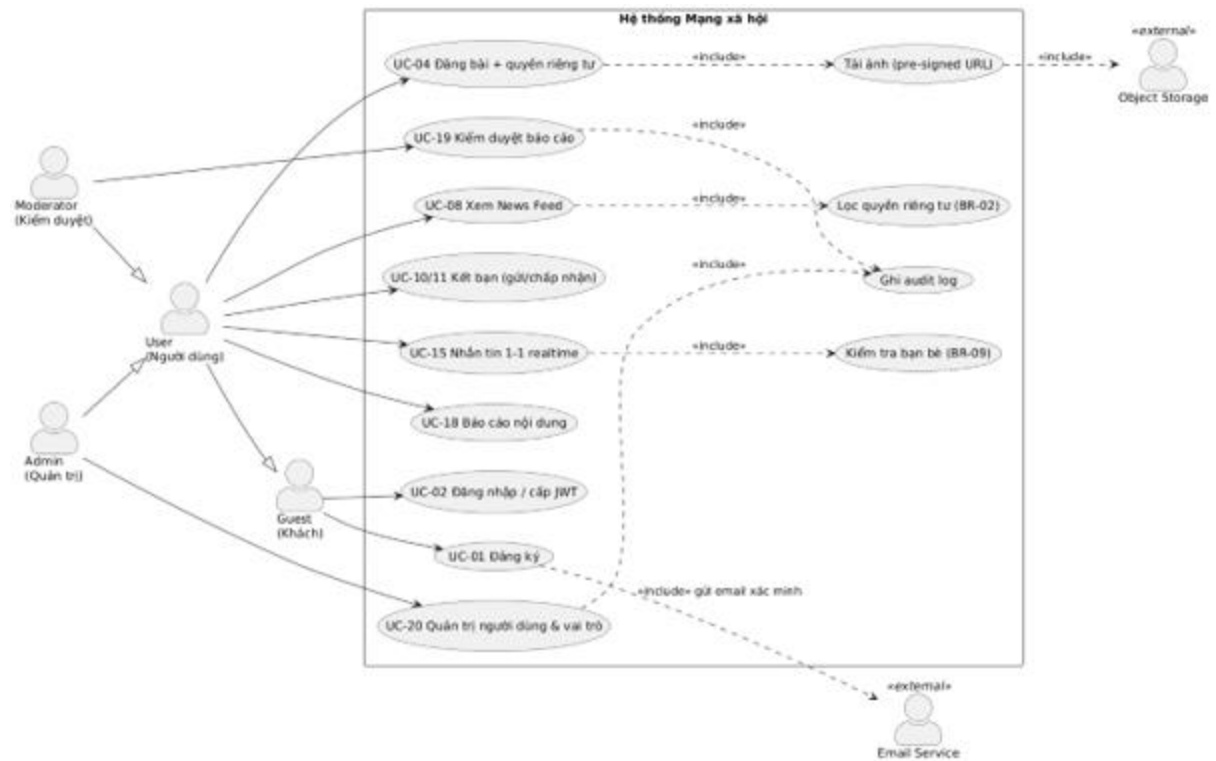
Thuật ngữ	Định nghĩa duy nhất	Từ đồng nghĩa cần tránh	Nguồn / Owner
News Feed	Dòng bài mới từ bạn bè và người đang theo dõi, phân trang cuộn vô hạn	Bảng tin, timeline	Content
Reaction (Cảm xúc)	Một loại cảm xúc của 1 người trên 1	Like	Content

Thuật ngữ	Định nghĩa duy nhất	Từ đồng nghĩa cần tránh	Nguồn / Owner
	bài/bình luận (BR-05)		
Friendship	Quan hệ bạn bè hai chiều của một cặp người dùng (BR-03)	Kết nối	Social Graph
Conversation	Hội thoại 1-1 giữa đúng 2 người dùng	Phòng chat	Messaging
Hidden	Trạng thái nội dung bị Moderator gỡ; tác giả vẫn thấy kèm lý do (BR-07)	Xóa	Moderation
Pre-signed URL	URL ký số có hạn để trình duyệt tải ảnh thẳng lên Object Storage	Link ảnh	DevOps
IDOR	Lỗi hỏng truy cập tài nguyên người khác bằng cách đổi ID trên URL	—	Security

2. Use Case Analysis

Mô tả mục tiêu của actor và tương tác với hệ thống ở mức nghiệp vụ.

2.1 System boundary và actor



Hình 1. Sơ đồ Use Case tổng quát (actor · use case · include/extend)

Actor ID	Actor	Loại	Mục tiêu chính	Quyền / giới hạn
ACT-G	Guest (Khách)	Primary	Đăng ký, đăng nhập, xem nội dung công khai	Không đăng bài / tương tác / nhắn tin
ACT-U	User (Người dùng)	Primary	Đăng bài, tương tác, kết bạn, theo dõi, nhắn tin	Chỉ thao tác trên tài nguyên của mình hoặc được phép xem
ACT-M	Moderator	Primary	Xử lý báo cáo, ẩn/gỡ nội dung vi phạm	Không xóa tài khoản, không đổi vai trò người khác
ACT-A	Admin	Primary	Quản lý người dùng & vai trò, khóa tài khoản, xem thống kê	Mọi thao tác được ghi audit log
ACT-ES	Email Service	External system	Gửi email xác minh, đặt lại mật khẩu	Chỉ nhận yêu cầu gửi mail từ hệ thống
ACT-OS	Object Storage	External system	Lưu trữ & phục vụ ảnh người	Truy cập qua URL ký số (pre-

Actor ID	Actor	Loại	Mục tiêu chính	Quyền / giới hạn
			dùng tải lên	signed URL)

2.2 Danh mục Use Case

ID	Tên Use Case	Primary actor	Mục tiêu / giá trị	Priority	Status
UC-01	Đăng ký tài khoản	Guest	Có tài khoản để dùng hệ thống	Must	Ready
UC-02	Đăng nhập / Đăng xuất	Guest, User	Truy cập an toàn bằng JWT	Must	Ready
UC-03	Quản lý hồ sơ cá nhân	User	Cập nhật ảnh đại diện, tiểu sử	Must	Ready
UC-04	Đăng bài viết	User	Chia sẻ nội dung theo quyền riêng tư	Must	Ready
UC-05	Sửa / Xóa bài viết	User	Kiểm soát nội dung đã đăng	Must	Ready
UC-06	Bình luận bài viết	User	Trao đổi dưới bài, trả lời 3 cấp	Must	Ready
UC-07	Thả / gỡ cảm xúc	User	Bày tỏ thái độ nhanh	Must	Ready
UC-08	Xem News Feed	User	Theo dõi nội dung mới	Must	Ready
UC-09	Xem trang cá nhân	Guest, User	Xem hồ sơ/bài theo quyền riêng tư	Must	Ready
UC-10	Gửi / hủy lời mời kết bạn	User	Thiết lập quan hệ bạn bè	Must	Ready
UC-11	Chấp nhận / từ chối lời mời	User	Kiểm soát ai là bạn của mình	Must	Ready
UC-12	Hủy kết bạn	User	Chấm dứt quan hệ bạn	Should	Ready

ID	Tên Use Case	Primary actor	Mục tiêu / giá trị	Priority	Status
			bè		
UC-13	Theo dõi / bỏ theo dõi	User	Nhận nội dung công khai không cần kết bạn	Must	Ready
UC-15	Nhắn tin 1-1	User	Trao đổi riêng tư realtime, có trạng thái đã xem	Must	Ready
UC-16	Tìm kiếm người dùng	User	Tìm bạn bè theo tên (không dấu)	Should	Ready
UC-17	Nhận và xem thông báo	User	Biết kịp thời tương tác liên quan	Should	Ready
UC-18	Báo cáo nội dung / người dùng	User	Yêu cầu kiểm duyệt nội dung vi phạm	Should	Ready
UC-19	Kiểm duyệt báo cáo	Moderator	Xử lý báo cáo: ẩn/gỡ, cảnh cáo	Should	Ready
UC-20	Quản trị người dùng & vai trò	Admin	Khóa/mở tài khoản, gán vai trò	Should	Ready

Ghi chú: UC-14 (Chặn/bỏ chặn người dùng) đã đưa ra ngoài phạm vi (thay bằng BR-09); mã số để trống nhằm giữ nguyên đánh số các UC còn lại. Mục 2.3 đặc tả chi tiết 6 UC lỗi (UC-02, UC-04, UC-08, UC-10/11, UC-15, UC-19); các UC còn lại giữ ở dạng danh mục.

2.3 Đặc tả Use Case chi tiết

UC-02 · Đăng nhập / cấp JWT

Trường	Nội dung
Use Case ID / Name	UC-02 · Đăng nhập / cấp JWT
Goal	Người dùng truy cập an toàn vào tài khoản, nhận access token + refresh token
Primary actor	ACT-U (User) / ACT-G (Guest chuyển thành User sau đăng nhập)
Supporting actors / systems	—

Trường	Nội dung
Trigger	Người dùng gửi email + mật khẩu ở màn hình đăng nhập
Preconditions	Tài khoản đã tồn tại và đã xác minh email
Minimal guarantee	Không lộ email nào tồn tại; đếm số lần sai để chống dò mật khẩu
Success guarantee	Cấp access token (JWT 15 phút) + refresh token (xoay vòng); ghi refresh token dạng băm
Frequency / Volume	Rất cao (mọi phiên làm việc)
Related	GOAL-03; US-002/AC-01..03; FR-002, FR-003; BR—; API-Auth-Login; ENT-01, ENT-11; NFR-SEC-01..03

Luồng chính

Bước	Actor thực hiện	Hệ thống phản hồi
1	Nhập email + mật khẩu, nhấn Đăng nhập	Nhận POST /api/v1/auth/login
2	—	Tra người dùng theo email; kiểm tra trạng thái khóa
3	—	Verify mật khẩu bằng BCrypt (cost 12)
4	—	Phát access token (JWT 15 phút) + refresh token; lưu refresh token dạng băm
5	—	Trả 200 kèm cặp token; reset failed_login_count

Luồng thay thế và ngoại lệ

Luồng	Điểm rẽ / điều kiện	Xử lý	Kết quả
E1 – Exception	Bước 3: sai mật khẩu	failed_login_count++; thông báo lỗi chung	401, không lộ email tồn tại
E2 – Exception	Bước 2: sai > 5 lần liên tiếp	Khóa đăng nhập 15 phút (FR-003)	423 Locked
E3 – Exception	Tài khoản chưa xác minh email	Từ chối, gợi ý gửi lại email xác minh	403

UC-04 · Đăng bài viết

Trường	Nội dung
Use Case ID / Name	UC-04 · Đăng bài viết
Goal	Người dùng chia sẻ nội dung văn bản kèm ảnh và đặt quyền riêng tư cho bài
Primary actor	ACT-U (User)
Supporting actors / systems	ACT-OS (Object Storage)
Trigger	Người dùng nhấn nút “Đăng bài”
Preconditions	Đã đăng nhập, JWT hợp lệ (UC-02)
Minimal guarantee	Không tạo bài không hợp lệ; ảnh tải dở được job nền dọn
Success guarantee	Bài lưu bền, hiển thị đúng quyền riêng tư (BR-02); người được gán thẻ nhận thông báo
Frequency / Volume	~5.000 bài/ngày
Related	GOAL-01; US-004/AC-01..03; FR-004; BR-01, BR-02; API-Post-Create; ENT-02; NFR-PERF-02

Luồng chính

Bước	Actor thực hiện	Hệ thống phản hồi
1	Soạn nội dung, chọn ≤ 10 ảnh, chọn quyền riêng tư	Hiển thị trình soạn thảo; kiểm tra sơ bộ phía client
2	Xác nhận tải ảnh	Cấp pre-signed URL (hạn 10 phút) cho từng ảnh
3	Trình duyệt PUT ảnh thẳng lên Object Storage	Không qua API; trả 200 mỗi ảnh
4	Nhấn “Đăng”	Validate BR-01 (≤ 5.000 ký tự hoặc ≥ 1 ảnh; ≤ 10 ảnh)
5	—	Lưu bài + media trong 1 transaction; trạng thái Published
6	—	Phát event PostCreated → thông báo người gán thẻ; trả 201

Luồng thay thế và ngoại lệ

Luồng	Điểm rẽ / điều kiện	Xử lý	Kết quả
A1 – Alternative	Bước 1: lưu nhập	Lưu nhập phía client, chưa gọi API	Soạn lại sau
E1 – Exception	Bước 4: vi phạm BR-01	Trả 400 kèm lỗi theo field (RFC 7807)	Không tạo bài
E2 – Exception (thiếu quyền)	Bước 4: JWT thiếu/hết hạn	Trả 401	Đăng nhập lại (refresh token)
E3 – Exception	Bước 5: lỗi ghi DB	Rollback; ảnh mờ cô đọng theo job nền	Trả 500; cho thử lại

Sơ đồ tuần tự cho luồng này: xem **Hình 7** (SEQ-01 · Đăng bài) ở Mục 6.5.

UC-08 · Xem News Feed

Trường	Nội dung
Use Case ID / Name	UC-08 · Xem News Feed
Goal	Người dùng xem dòng bài mới từ bạn bè và người đang theo dõi
Primary actor	ACT-U (User)
Supporting actors / systems	— (Redis cache nội bộ)
Trigger	Người dùng mở trang chủ / cuộn xuống
Preconditions	Đã đăng nhập
Minimal guarantee	Không hiển thị bài người dùng không có quyền xem (BR-02, BR-07)
Success guarantee	Trả 20 bài đúng quyền riêng tư, sắp xếp thời gian giảm dần, kèm cursor kế tiếp
Frequency / Volume	Rất cao (~500k lượt đọc/ngày); truy vấn nặng nhất
Related	GOAL-01; US-008/AC-01..02; FR-009; BR-02, BR-07; API-Feed; ENT-02; NFR-PERF-01; ADR-004

Luồng chính

Bước	Actor thực hiện	Hệ thống phản hồi
1	Mở News Feed	Nhận GET /api/v1/feed?cursor=&limit=
2	—	Lấy danh sách bạn bè + đang theo dõi (cache Redis 60s)

Bước	Actor thực hiện	Hệ thống phản hồi
3	—	Kiểm tra cache trang đầu (TTL 30s); nếu miss thì truy vấn index (fan-out-on-read)
4	—	Lọc quyền riêng tư BR-02 + loại bài Hidden BR-07
5	—	Trả 20 bài + cursor kế tiếp; kèm số cảm xúc/bình luận

Luồng thay thế và ngoại lệ

Luồng	Điểm rẽ / điều kiện	Xử lý	Kết quả
A1 – Alternative	Người dùng mới chưa có kết nối	Trả feed gợi ý bài công khai mới nhất	Feed không trống
E1 – Exception	Cursor sai định dạng	Trả 400	Client tải lại từ đầu
E2 – Exception	Redis chết	Đọc thẳng DB (degrade), ghi log cảnh báo	Vẫn phục vụ
E3 – Exception	DB timeout > 5s	Trả 503 + Retry-After	Client thử lại

UC-10/11 · Gửi & phản hồi lời mời kết bạn

Trường	Nội dung
Use Case ID / Name	UC-10/11 · Gửi và chấp nhận/từ chối lời mời kết bạn
Goal	Thiết lập quan hệ bạn bè hai chiều, có kiểm soát của người nhận
Primary actor	ACT-U (User) — người gửi và người nhận
Supporting actors / systems	—
Trigger	Người dùng nhấn “Kết bạn” trên trang cá nhân người khác
Preconditions	Cả hai đã đăng nhập; chưa là bạn bè
Minimal guarantee	Mỗi cặp chỉ 1 quan hệ (BR-03); không tự kết bạn với chính mình
Success guarantee	Trạng thái chuyển Pending → Accepted khi được chấp nhận; thông báo cho hai bên
Frequency / Volume	Trung bình

Trường	Nội dung
Related	GOAL-03; US-010/AC-01..03; FR-010, FR-011; BR-03; API-Friend-Request, API-Friend-Respond; ENT-04

Luồng chính

Bước	Actor thực hiện	Hệ thống phản hồi
1	A gửi lời mời tới B	Validate BR-03; tạo bản ghi Friendship trạng thái Pending
2	—	Thông báo cho B (UC-17); trả 201
3	B chấp nhận	Chuyển Pending → Accepted (1 UPDATE atomically)
4	—	Thông báo cho A; hai bên thành bạn bè

Luồng thay thế và ngoại lệ

Luồng	Điểm rẽ / điều kiện	Xử lý	Kết quả
A1 – Alternative	B từ chối lời mời	Xóa bản ghi Pending	Không thành bạn
A2 – Alternative	A hủy lời mời đang chờ	Xóa bản ghi Pending	Trở về trạng thái ban đầu
E1 – Exception	Đã tồn tại quan hệ (Pending/Accepted)	Trả 409	Không tạo trùng
E2 – Exception	A tự gửi cho chính mình	Trả 400	Bị từ chối
E3 – Exception (thiếu quyền)	B phản hồi lời mời không dành cho mình	Trả 403	Bị từ chối

UC-15 · Nhắn tin 1-1 realtime

Trường	Nội dung
Use Case ID / Name	UC-15 · Nhắn tin 1-1 realtime
Goal	Hai người bạn trao đổi riêng tư theo thời gian thực, có trạng thái đã xem
Primary actor	ACT-U (người gửi A và người nhận B)
Supporting actors / systems	Redis (presence/backplane)
Trigger	A gõ tin và nhấn gửi trong hội thoại

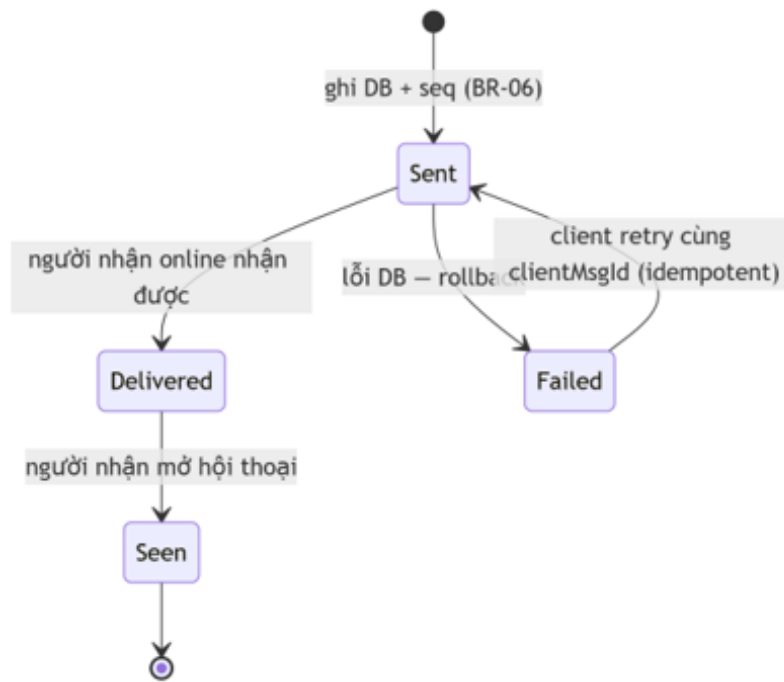
Trường	Nội dung
Preconditions	A và B đang là bạn bè (BR-09); đã đăng nhập
Minimal guarantee	Chỉ 2 thành viên hội thoại đọc/gửi được (BR-06); không mất/không trùng tin
Success guarantee	Tin lưu bền + đẩy tới B ≤ 1 giây khi B online; cập nhật Sent→Delivered→Seen
Frequency / Volume	Cao (~50k tin/ngày)
Related	GOAL-02; US-015/AC-01..03; FR-015, FR-016; BR-06, BR-09; API-Message-Send; ENT-06, ENT-07; NFR-PERF-03

Luồng chính

Bước	Actor thực hiện	Hệ thống phản hồi
1	A gửi SendMessage(convId, content, clientMsgId) qua WebSocket	ChatHub nhận; validate JWT + BR-06 + quan hệ bạn bè BR-09
2	—	INSERT message (transaction: message + seq + last_message)
3	—	ACK cho A (status=Sent); tra presence B trong Redis
4	—	B online: đẩy message tới B
5	B mở hội thoại	Cập nhật Delivered → Seen; phát ngược lại A

Luồng thay thế và ngoại lệ

Luồng	Điểm rẽ / điều kiện	Xử lý	Kết quả
A1 – Alternative	B offline	Tăng bộ đếm chưa đọc + tạo notification	Nhận khi B online
A2 – Alternative	Mất WebSocket	Client fallback REST POST .../messages	Vẫn gửi được
E1 – Exception	Lỗi ghi DB	Rollback; client retry cùng clientMsgId	UQ(conv, clientMsgId) khử trùng
E2 – Exception (thiếu quyền)	A và B không phải bạn bè	Từ chối gửi (BR-09)	403; hội thoại chỉ đọc



Hình 2. Máy trạng thái — Tin nhắn (*Sent* → *Delivered* → *Seen*; *Failed* → *retry*)

Sơ đồ tuần tự gửi tin realtime: xem **Hình 8** (SEQ-02) ở Mục 6.5.

UC-19 · Kiểm duyệt báo cáo

Trường	Nội dung
Use Case ID / Name	UC-19 · Kiểm duyệt báo cáo
Goal	Moderator xử lý báo cáo vi phạm: ẩn/gỡ nội dung hoặc bỏ qua, có audit
Primary actor	ACT-M (Moderator)
Supporting actors / systems	ACT-U (người báo cáo, UC-18)
Trigger	Moderator mở hàng đợi báo cáo
Preconditions	Đăng nhập với vai trò Moderator; có báo cáo trạng thái Open
Minimal guarantee	Mọi hành động ghi audit log không sửa/xóa được; một báo cáo chỉ có 1 kết luận
Success guarantee	Nội dung vi phạm chuyển Hidden (BR-07); báo cáo chuyển Resolved/Dismissed
Frequency / Volume	Thấp
Related	GOAL-03; US-019/AC-01..03; FR-019, FR-020; BR-07; API-Reports; ENT-12, ENT-13

Luồng chính

Bước	Actor thực hiện	Hệ thống phản hồi
1	Mở hàng đợi báo cáo	Trả danh sách report trạng thái Open
2	Chọn một báo cáo, xem nội dung	Hiển thị chi tiết đối tượng bị báo cáo
3	Quyết định “ẩn nội dung”	post.status = Hidden (BR-07); report = Resolved; ghi audit_log (cùng transaction)
4	—	Thông báo tác giả kèm lý do; trả 200

Luồng thay thế và ngoại lệ

Luồng	Điểm rẽ / điều kiện	Xử lý	Kết quả
A1 – Alternative	Không vi phạm	report = Dismissed + audit_log	Nội dung giữ nguyên
E1 – Exception (thiếu quyền)	User thường gọi endpoint kiểm duyệt	Trả 403 (default deny)	Bị từ chối + audit
E2 – Exception	Báo cáo đã được xử lý	Trả 409	Không xử lý lại

2.4 Business Rules phát hiện từ Use Case

Rule ID	Phát biểu quy tắc	Nguồn	Áp dụng cho	Cách kiểm chứng
BR-01	Bài viết phải có văn bản (≤ 5.000 ký tự) hoặc ≥ 1 ảnh; tối đa 10 ảnh, mỗi ảnh $\leq 10\text{MB}$	UC-04	FR-004, ENT-02	Test API + CHECK constraint
BR-02	Quyền xem bài: Công khai—mọi người; Bạn bè—chỉ bạn bè; Riêng tư—chỉ tác giả. Đánh giá tại thời điểm đọc	UC-04, UC-08	FR-006, ENT-02	Integration test theo ma trận quyền
BR-03	Mỗi cặp người dùng tối đa 1 quan hệ bạn bè (Pending/Accepted); không tự	UC-10/11	FR-010, ENT-04	UNIQUE + CHECK user_min < user_max

Rule ID	Phát biểu quy tắc	Nguồn	Áp dụng cho	Cách kiểm chứng
	kết bạn			
BR-05	Mỗi người chỉ 1 cảm xúc trên 1 bài/bình luận; thả loại khác thì thay thế	UC-07	FR-008, ENT-05	PK(user, target_type, target_id)
BR-06	Chỉ 2 thành viên của hội thoại được đọc/gửi tin	UC-15	FR-016, ENT-06	AuthZ test
BR-07	Nội dung bị gỡ chuyển Hidden: tác giả thấy kèm lý do, người khác không thấy	UC-19	FR-006, ENT-02	Test hiển thị theo vai trò
BR-08	Bình luận tối đa 3 cấp; xóa thì hiển thị “Bình luận đã bị xóa” giữ nhánh trả lời	UC-06	FR-007, ENT-03	Test tăng ứng dụng
BR-09	Chỉ bạn bè mới tạo hội thoại và nhắn tin; hủy kết bạn → hội thoại chỉ đọc (thay tính năng chặn)	UC-15	FR-015, ENT-06	AuthZ test

Ghi chú: mã **BR-04** để trống có chủ đích (quy tắc “chặn người dùng” đã loại khỏi phạm vi cùng UC-14, thay bằng BR-09); giữ nguyên đánh số các quy tắc còn lại.

3. User Story và Acceptance Criteria

Chuyên mục tiêu người dùng thành lát cắt có thể ưu tiên, xây dựng và nghiệm thu.

3.1 Cấu trúc backlog

Cấp	Mục đích	Quy mô gợi ý	Ví dụ mã
Epic	Kết quả lớn, nhiều release	Nhiều giai đoạn	EPIC-01
Feature	Nhóm năng lực có giá trị	1–2 giai đoạn	FEAT-Content
User Story	Lát cắt kiểm thử được	Trong một giai đoạn	US-008
Task	Công việc kỹ thuật	≤ 1–2 ngày	TASK-118

3.2 Danh mục User Story

ID	Epic / Feature	User Story	Priority	Est.	Status
US-001	FEAT-Account	Là Guest, tôi muốn đăng ký bằng email và xác minh, để có tài khoản dùng hệ thống	Must	3	Ready
US-002	FEAT-Account	Là người dùng, tôi muốn đăng nhập an toàn bằng JWT, để truy cập tài khoản	Must	3	Ready
US-003	FEAT-Profile	Là người dùng, tôi muốn cập nhật hồ sơ và ảnh đại diện, để thể hiện danh tính	Must	2	Ready
US-004	FEAT-Content	Là người dùng, tôi muốn đăng bài kèm ảnh và đặt quyền riêng tư, để chia sẻ có kiểm soát	Must	5	Ready
US-006	FEAT-Interaction	Là người dùng, tôi muốn bình luận (tối đa 3 cấp), để trao đổi dưới bài	Must	3	Ready
US-007	FEAT-Interaction	Là người dùng, tôi	Must	2	Ready

ID	Epic / Feature	User Story	Priority	Est.	Status
		muốn thả/đổi cảm xúc, để bày tỏ thái độ nhanh			
US-008	FEAT-Feed	Là người dùng, tôi muốn xem News Feed từ bạn bè và người theo dõi, để cập nhật nhanh	Must	5	Ready
US-010	FEAT-Social	Là người dùng, tôi muốn gửi và phản hồi lời mời kết bạn, để thiết lập quan hệ	Must	3	Ready
US-013	FEAT-Social	Là người dùng, tôi muốn theo dõi/bỏ theo dõi, để nhận nội dung công khai	Must	2	Ready
US-015	FEAT-Messaging	Là người dùng, tôi muốn nhắn tin 1-1 realtime với bạn bè, để trao đổi riêng tư	Must	8	Ready
US-016	FEAT-Search	Là người dùng, tôi muốn tìm người dùng theo tên (không dấu), để kết	Should	2	Ready

ID	Epic / Feature	User Story	Priority	Est.	Status
		nói			
US-017	FEAT-Notification	Là người dùng, tôi muốn nhận thông báo tương tác, để biết kịp thời	Should	3	Ready
US-018	FEAT-Moderation	Là người dùng, tôi muốn báo cáo nội dung vi phạm, để yêu cầu kiểm duyệt	Should	2	Ready
US-019	FEAT-Moderation	Là Moderator, tôi muốn xử lý hàng đợi báo cáo, để gỡ nội dung vi phạm	Should	3	Ready

*Ghi chú: các mã **US-005, US-009, US-011, US-012, US-014** để trống có chủ đích — tương ứng các UC gộp/ngoài phạm vi (UC-05 và UC-11 đã gộp vào US-004/US-010; UC-12/UC-14 ngoài phạm vi MVP). Giữ nguyên đánh số để đồng bộ với UC.*

3.3 Biểu mẫu User Story chi tiết — US-008

Trường	Nội dung
Story ID / Title	US-008 · Xem News Feed
Statement	Là người dùng đã đăng nhập, tôi muốn xem dòng bài mới từ bạn bè và người tôi theo dõi, để cập nhật nhanh mà không bỏ lỡ nội dung
Context / Notes	Feed là điểm vào chính, quyết định mức gắn bó của người dùng; đồng thời là truy vấn nặng nhất về hiệu năng
Related Use Case	UC-08 (luồng chính)
Dependencies	US-004 (có bài để hiển thị); US-010, US-013 (quan hệ để lọc feed)
Data involved	ENT-02 Post, ENT-04 Friendship, ENT-04a Follow

Trường	Nội dung
NFR applicable	NFR-PERF-01 ($p95 \leq 500 \text{ ms @ } 1.000 \text{ CCU}$)
Out of scope	Xếp hạng theo mức độ quan tâm (kỳ này chỉ sắp theo thời gian giảm dần)

3.4 Acceptance Criteria theo Given–When–Then

US-002 · Đăng nhập

AC ID	Scenario	Given	When	Then
US-002/AC-01	Happy path	Tài khoản đã xác minh email	Nhập đúng email + mật khẩu	Nhận access token (15 phút) + refresh token; vào trang chủ
US-002/AC-02	Sai mật khẩu	Email đúng, mật khẩu sai	Gửi đăng nhập	401 “Sai thông tin”; không lộ email tồn tại; failed_login_count++
US-002/AC-03	Lockout	Đã sai 5 lần liên tiếp	Thử đăng nhập lần 6	423 Locked; khóa 15 phút
US-002/AC-04	Chưa xác minh	Tài khoản chưa xác minh email	Đăng nhập đúng mật khẩu	403; gợi ý gửi lại email xác minh

US-004 · Đăng bài

AC ID	Scenario	Given	When	Then
US-004/AC-01	Happy path	Đã đăng nhập, đã upload 3 ảnh	Đăng bài quyền “Công khai”	201; bài xuất hiện trên feed bạn bè
US-004/AC-02	Validation	Bài rỗng và không có ảnh	Nhấn Đăng	400 (vi phạm BR-01); không tạo bài
US-004/AC-03	Validation	Chọn 11 ảnh	Nhấn Đăng	400 “tối đa 10 ảnh”
US-004/AC-04	Authorization	JWT hết hạn	Nhấn Đăng	401; chuyển đăng nhập lại

US-008 · Xem News Feed

AC ID	Scenario	Given	When	Then
US-008/AC-01	Happy path	Có bạn bè đã đăng bài	Mở feed	20 bài mới nhất, sắp thời gian

AC ID	Scenario	Given	When	Then
				giảm dần + cursor kế tiếp
US-008/AC-02	Privacy (BR-02)	Bài “Chỉ bạn bè” của người không phải bạn	Mở feed	Bài đó KHÔNG xuất hiện
US-008/AC-03	Hidden (BR-07)	Một bài bị Moderator gỡ	Mở feed (người khác tác giả)	Bài không xuất hiện
US-008/AC-04	Performance	1.000 người dùng đồng thời	Tải feed	$p95 \leq 500$ ms (NFR-PERF-01)

US-010 · Kết bạn

AC ID	Scenario	Given	When	Then
US-010/AC-01	Happy path	A và B chưa là bạn	A gửi lời mời, B chấp nhận	Quan hệ Accepted; hai bên là bạn; cả hai được thông báo
US-010/AC-02	Trùng	A và B đã có quan hệ	A gửi lại lời mời	409 “đã tồn tại”
US-010/AC-03	Validation	A gửi cho chính mình	Gửi lời mời	400
US-010/AC-04	Authorization	Lời mời gửi cho B	C (không phải B) bấm chấp nhận	403

US-015 · Nhắn tin realtime

AC ID	Scenario	Given	When	Then
US-015/AC-01	Happy path	A, B là bạn; B online	A gửi tin	B nhận ≤ 1 s; trạng thái Sent → Delivered → Seen
US-015/AC-02	B offline	A, B là bạn; B offline	A gửi tin	Tin lưu bền; B nhận + badge khi online lại
US-015/AC-03	Idempotency	Mất mạng, client thử lại cùng <code>clientMsgId</code>	Gửi lại	Không tạo tin trùng (UQ conversation, <code>clientMsgId</code>)
US-015/AC-04	Authorization (BR-09)	A và B không phải bạn bè	A gửi tin	403; hội thoại chỉ đọc

US-019 · Kiểm duyệt báo cáo

AC ID	Scenario	Given	When	Then
US-019/AC-01	Happy path	Moderator; báo cáo Open vi phạm	Chọn “ẩn nội dung”	post=Hidden (BR-07); report=Resolved ; có audit_log
US-019/AC-02	Bỏ qua	Nội dung không vi phạm	Chọn “bỏ qua”	report=Dismissed; nội dung giữ nguyên; có audit_log
US-019/AC-03	Authorization	User thường (không phải Moderator)	Gọi endpoint kiểm duyệt	403 (default deny) + audit
US-019/AC-04	Idempotency	Báo cáo đã xử lý	Xử lý lại	409

3.5 Definition of Ready / Definition of Done**Definition of Ready**

- ☐ Giá trị và actor rõ ràng
- ☐ Acceptance Criteria có thể kiểm thử
- ☐ Phụ thuộc đã biết
- ☐ Dữ liệu/NFR liên quan đã gắn mã
- ☐ Nhóm hiểu và ước lượng được

Definition of Done

- ☐ Đáp ứng đủ Acceptance Criteria của story
- ☐ Có kiểm tra phân quyền: đúng vai trò (RBAC) và đúng chủ sở hữu tài nguyên
- ☐ Có xác thực đầu vào và trả lỗi theo định dạng chuẩn (RFC 7807)
- ☐ Đã chạy thử trên staging bằng tài khoản thật
- ☐ Đã cập nhật tài liệu API (Swagger) và mục liên quan
- ☐ Không còn secret/PII ngoài kiểm soát

4. Functional Requirements và Non-Functional Requirements**4.1 Functional Requirements (FR)**

Mẫu phát biểu: “Hệ thống phải [hành vi] khi [điều kiện], để [kết quả quan sát được].”

FR ID	Requirement	Source	Priority	Verification
FR-001	Tạo tài khoản mới khi email chưa tồn tại và mật khẩu đạt chuẩn (≥ 8 ký tự, có chữ hoa, số),	UC-01	Must	API test

FR ID	Requirement	Source	Priority	Verification
	gửi email xác minh			
FR-002	Cấp access token (JWT, hạn 15 phút) và refresh token (7 ngày, xoay vòng) khi đăng nhập đúng	UC-02	Must	API test
FR-003	Khóa đăng nhập 15 phút sau 5 lần nhập sai liên tiếp	UC-02	Must	Test
FR-004	Lưu bài viết gồm văn bản (≤ 5.000 ký tự) và 0–10 ảnh theo BR-01	UC-04, BR-01	Must	API test
FR-005	Cho tác giả sửa nội dung hoặc xóa mềm bài của mình; bài xóa không hiển thị ở mọi luồng đọc	UC-05	Must	API test
FR-006	Lọc mọi luồng đọc (feed, trang cá nhân, tìm kiếm) theo quyền riêng tư BR-02 và trạng thái BR-07	UC-08, UC-09	Must	Integration test
FR-007	Lưu bình luận (≤ 1.000 ký tự), hỗ trợ trả lời tối đa 3 cấp theo BR-08	UC-06, BR-08	Must	API test
FR-008	Ghi nhận, đổi hoặc gỡ cảm xúc theo BR-05 và cập nhật bộ đếm theo từng loại	UC-07, BR-05	Must	API test
FR-009	Trả về News Feed từ bạn bè và người đang theo dõi, thời	UC-08	Must	API + load test

FR ID	Requirement	Source	Priority	Verification
	gian giảm dần, phân trang cursor 20 bài			
FR-010	Tạo lời mời kết bạn trạng thái Pending khi thỏa BR-03 và thông báo cho người nhận	UC-10, BR-03	Must	API test
FR-011	Chuyển quan hệ sang Accepted khi chấp nhận, hoặc xóa bản ghi khi từ chối/hủy	UC-11	Must	API test
FR-012	Tạo/gỡ quan hệ theo dõi một chiều ngay khi thao tác, không cần phê duyệt	UC-13	Must	API test
FR-013	Hiển thị trang cá nhân gồm hồ sơ, danh sách bạn bè và dòng bài đã lọc quyền	UC-09	Must	Integration test
FR-015	Lưu bên tin nhắn và đẩy tới người nhận qua kênh realtime trong ≤ 1 giây khi online	UC-15	Must	E2E test
FR-016	Chỉ 2 thành viên hội thoại đọc/gửi tin và cập nhật trạng thái Sent/Delivered/Seen	UC-15, BR-06	Must	AuthZ test
FR-017	Tìm người dùng theo tên hiển thị (khớp không dấu, tiền tố)	UC-16	Should	API test
FR-018	Tạo thông báo khi có bình luận, cảm xúc, gán thẻ, lời mời,	UC-17	Should	Integration test

FR ID	Requirement	Source	Priority	Verification
	chấp nhận, tin nhắn mới; gộp cùng loại			
FR-019	Tiếp nhận báo cáo nội dung với lý do chuẩn hóa và đưa vào hàng đợi kiểm duyệt	UC-18	Should	API test
FR-020	Cho Moderator ẩn/khôi phục nội dung (BR-07) và Admin khóa/mở tài khoản, gán vai trò; ghi audit log	UC-19, UC-20, BR-07	Should	Role-based test

Ghi chú: mã **FR-014** để trống có chủ đích (yêu cầu gắn với UC-14 “chặn người dùng” đã loại khỏi phạm vi); giữ nguyên đánh số các FR còn lại.

4.2 Mẫu FR chi tiết — FR-009

Trường	Nội dung
FR ID / Name	FR-009 · Trả về News Feed
Statement	Hệ thống phải trả về News Feed gồm bài của bạn bè (Công khai + Bạn bè) và người đang theo dõi (chỉ Công khai), sắp theo thời gian giảm dần, phân trang cursor 20 bài/trang
Rationale	Feed là điểm vào chính, quyết định mức gắn bó; đồng thời là truy vấn nặng nhất về hiệu năng
Source	GOAL-01; UC-08; US-008; BR-02, BR-07
Precondition / Trigger	Đã đăng nhập; gọi GET /api/v1/feed
Inputs / Outputs	Input: cursor (tùy chọn), limit ≤ 50 . Output: bài kèm số bình luận, số cảm xúc theo loại, cảm xúc của người xem, cursor kế. Lỗi: 401, 400
Rules / Exceptions	BR-02 (quyền riêng tư), BR-07 (Hidden không xuất hiện); người dùng mới chưa kết nối trả feed gợi ý công khai
Priority / Risk / Owner	Must / High (rủi ro hiệu năng) / R1
Verification	Integration test theo ma trận quyền xem; load test k6 tại 1.000 CCU đối chiếu NFR-PERF-

Trường	Nội dung
	01

4.3 Non-Functional Requirements (NFR)

NFR gắn với scenario, metric, ngưỡng và môi trường đo; kiểm chứng được, không phải khẩu hiệu.

Category	Câu hỏi thiết kế	Metric / ngưỡng áp dụng
Performance	Feed, trang cá nhân, gửi tin nhanh đến đâu ở 1.000 CCU?	p95 latency; xem NFR-PERF-01...03
Availability / Reliability	Được phép ngừng bao lâu; tin nhắn có được phép mất?	Uptime $\geq 99\%$ /tháng; RPO ≤ 15 phút; RTO ≤ 2 giờ
Security / Privacy	JWT, RBAC, mật khẩu, PII được bảo vệ thế nào?	Xem NFR-SEC-01...04
Scalability	Tải tăng theo người hoạt động và số tin/giây	API stateless, scale ngang; xem NFR-SCAL-01
Usability	Dùng được trên mobile web và desktop	Responsive $\geq 360px$; thao tác cốt lõi ≤ 3 bước
Maintainability	Thay đổi và kiểm thử dễ đến đâu?	Coverage $\geq 70\%$ tầng nghiệp vụ; build + test CI ≤ 10 phút
Observability	Phát hiện lỗi trong bao lâu?	Alert khi error rate $> 1\%/5$ phút; log có correlation ID
Compliance / Audit	Nghĩa vụ với dữ liệu cá nhân?	NĐ 13/2023/NĐ-CP: quyền xóa tài khoản, audit truy cập

4.4 Danh mục NFR

NFR ID	Scenario / Requirement	Metric & Threshold	Scope	Verification	Pri.
NFR-PERF-01	1.000 người tải Feed đồng thời, hệ thống phản hồi ổn định	p95 ≤ 500 ms; error rate $< 0,5\%$	API-Feed	Load test k6	Must
NFR-PERF-02	Tạo bài kèm 3 ảnh (đã upload) phải nhanh	p95 ≤ 800 ms	API-Post-Create	Load test	Must
NFR-PERF-03	Người nhận online, tin tới trình duyệt gần tức thời	p95 ≤ 1 s từ lúc gửi	Realtime Hub	E2E đo tự động	Must

NFR ID	Scenario / Requirement	Metric & Threshold	Scope	Verification	Pri.
NFR-SEC-01	Mật khẩu băm không đảo ngược	BCrypt work factor ≥ 12 ; không lưu plaintext	Identity	Code review	Must
NFR-SEC-02	Mọi endpoint (trừ công khai) yêu cầu JWT + RBAC + ownership	100% endpoint có policy; 0 endpoint hở	Toàn API	AuthZ test tự động	Must
NFR-SEC-03	Token bị lộ, thiết hại giới hạn	Access token TTL 15 phút; refresh xoay vòng, thu hồi được	Identity	Test + review	Must
NFR-SEC-04	Truyền tải mã hóa; đầu vào chống OWASP Top 10	TLS 1.2+; 0 lỗi High/Critical khi quét ZAP + SQLi/XSS	Toàn hệ thống	Security scan	Must
NFR-REL-01	Một instance API lỗi, dịch vụ vẫn hoạt động	Uptime $\geq 99\%$ /tháng; health check loại instance lỗi ≤ 30 s	API container	Chaos drill	Should
NFR-REL-02	Mất dữ liệu do sự cố, mức mất và thời gian khôi phục giới hạn	RPO ≤ 15 phút; RTO ≤ 2 giờ	PostgreSQL	Restore drill	Must
NFR-SCAL-01	Người hoạt động tăng gấp 3, mở rộng không đổi kiến trúc	API stateless scale ngang; session không lưu server	API + Hub	Design review + load test	Should
NFR-OBS-01	Lỗi 5xx tăng bất thường, đội vận hành biết sớm	Alert ≤ 5 phút; mọi request có correlation ID	Toàn hệ thống	Alert drill	Should

NFR ID	Scenario / Requirement	Metric & Threshold	Scope	Verification	Pri.
NFR-COMP-01	Người dùng yêu cầu xóa tài khoản, xử lý đúng quy định	Vô hiệu hóa ngay; ẩn danh PII sau 30 ngày; log admin 12 tháng	Identity + Audit	Inspection	Must

4.5 Mẫu Quality Attribute Scenario — NFR-PERF-01

Thành phần	Nội dung
Source	1.000 người dùng đồng thời (kịch bản k6 mô phỏng lướt feed)
Stimulus	Mỗi người gọi GET /api/v1/feed trung bình 1 lần/10 giây, kèm 20% request tải trang kế
Environment	Peak — staging tương đương production (2 API container, 1 PostgreSQL 4 vCPU)
Artifact	API-Feed (gồm truy vấn PostgreSQL và cache Redis)
Response	Phục vụ toàn bộ request, không rớt kết nối; CPU DB < 80%
Response measure	p95 ≤ 500 ms; p99 ≤ 1.200 ms; error rate < 0,5% trong 30 phút chạy liên tục
Verification method	Load test k6 chạy từ máy riêng (không trên VPS đang đo); báo cáo kèm số liệu Grafana

5. Database Domain Design

Thiết kế dữ liệu bắt đầu từ ngôn ngữ và quy tắc nghiệp vụ, sau đó chuyển thành schema vật lý trên PostgreSQL 16.

5.1 Domain scope và bounded context / module

Context / Module	Trách nhiệm	Owns data	Upstream / Downstream
Identity & Access	Đăng ký, đăng nhập, JWT, RBAC, khóa tài khoản	ENT-01 User, ENT-10 Role, ENT-11 RefreshToken	Downstream: mọi module; External: Email
Profile	Hồ sơ: ảnh đại diện, ảnh bìa, tiểu sử	ENT-01a Profile	Upstream: Identity; Downstream: Search, Content

Context / Module	Trách nhiệm	Owns data	Upstream / Downstream
Social Graph	Kết bạn, theo dõi	ENT-04 Friendship, ENT-04a Follow	Downstream: Content (lọc feed), Messaging
Content	Bài viết, bình luận, cảm xúc, media	ENT-02 Post, ENT-03 Comment, ENT-05 Reaction, ENT-08 Media	Upstream: Social Graph; Downstream: Notification, Moderation
Messaging	Hội thoại 1-1, tin nhắn, trạng thái đã xem	ENT-06 Conversation, ENT-07 Message	Upstream: Social Graph; Downstream: Notification
Notification	Sinh, gộp, đánh dấu đã đọc thông báo	ENT-09 Notification	Upstream: Content, Social Graph, Messaging
Moderation & Admin	Báo cáo, kiểm duyệt, audit log	ENT-12 Report, ENT-13 AuditLog	Upstream: Content, Identity

5.2 Domain object catalog

ID	Tên	Loại	Định nghĩa / trách nhiệm	Identity / Equality	Owner
ENT-01	User	Aggregate root	Tài khoản định danh: email, mật khẩu, trạng thái, vai trò	user_id (UUID)	Identity
ENT-01a	Profile	Entity	Thông tin hiển thị công khai của User (1-1)	user_id	Profile
ENT-02	Post	Aggregate root	Bài viết: nội dung, quyền riêng tư, trạng thái, bộ đếm	post_id (UUID)	Content
ENT-03	Comment	Entity (thuộc Post)	Bình luận/trả lời tối đa 3 cấp	comment_id (UUID)	Content
ENT-04	Friendship	Aggregate root	Quan hệ bạn bè của cặp người dùng: Pending/Acc	cặp (user_min, user_max)	Social Graph

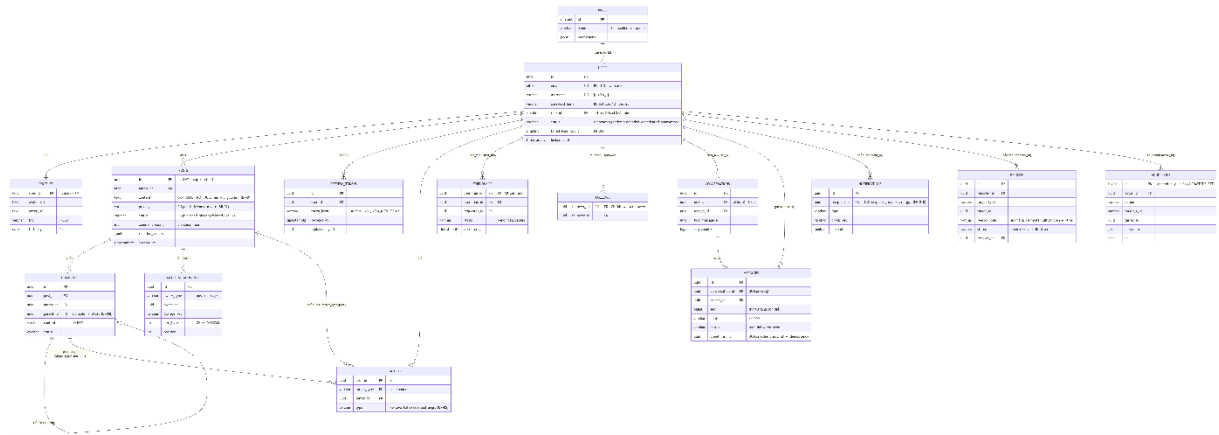
ID	Tên	Loại	Định nghĩa / trách nhiệm	Identity / Equality	Owner
			epted		
ENT-04a	Follow	Entity	Quan hệ theo dõi một chiều follower→followee	cặp (follower, followee)	Social Graph
ENT-05	Reaction	Value Object	Cảm xúc 1 loại của 1 người trên 1 đối tượng	(user, target_type, target_id)	Content
ENT-06	Conversation	Aggregate root	Hội thoại 1-1 duy nhất cho mỗi cặp	conversation_id (UUID)	Messaging
ENT-07	Message	Entity (thuộc Conversation)	Tin nhắn có thứ tự + trạng thái Sent/Delivered/Seen	message_id + seq	Messaging
ENT-08	MediaAttachment	Entity	Ảnh đính kèm, trữ tới Object Storage	media_id (UUID)	Content
ENT-09	Notification	Entity	Thông báo cho một người nhận, có thể gộp	notification_id (UUID)	Notification
ENT-10	Role	Reference data	Vai trò RBAC: User, Moderator, Admin	role_id (smallint)	Identity
ENT-10a	Permission	Reference data	Một quyền dạng resource.action (post.hide, report.resolve...)	permission_id (smallint)	Identity
ENT-10b	RolePermission	Entity (liên kết)	Gán quyền cho vai trò (n-n Role↔Permission) — hiện thực ma	(role_id, permission_id)	Identity

ID	Tên	Loại	Định nghĩa / trách nhiệm	Identity / Equality	Owner
			trên 6.7.2		
ENT-11	RefreshToken	Entity	Refresh token xoay vòng, thu hồi được	token_id (UUID)	Identity
ENT-12	Report	Aggregate root	Báo cáo vi phạm và kết quả xử lý	report_id (UUID)	Moderation
ENT-13	AuditLog	Event (append-only)	Nhật ký thao tác quản trị/kiểm duyệt	audit_id (bigserial)	Moderation

5.3 Aggregate và invariant

Aggregate root	Members	Invariant / Business Rules	Transaction boundary	Model
ENT-01 User	Profile, RefreshToken	Email duy nhất; mật khẩu luôn bấm (NFR-SEC-01); user khóa không đăng nhập	Tạo User + Profile cùng transaction	Strong
ENT-02 Post	Comment, Reaction, Media	BR-01, BR-05, BR-08; bộ đếm nhất quán với bản ghi thật	Tạo/xóa bài + media atomically; bộ đếm cùng transaction	Strong (feed hiển thị trễ $\leq 5s$)
ENT-04 Friendship	—	BR-03: 1 quan hệ/cặp, không tự kết bạn (CHECK user_min < user_max)	Pending → Accepted là 1 UPDATE	Strong
ENT-06 Conversation	Message	1 hội thoại/cặp; seq tăng đơn điệu; BR-06 chỉ 2 thành viên	Ghi tin + tăng seq + last_message atomically	Strong (Delivered/Seen eventual)
ENT-12 Report	—	Một báo cáo chỉ 1 kết luận; Open → Resolved/Dismissed một chiều	Cập nhật kết luận + ghi AuditLog cùng transaction	Strong

5.4 Conceptual ERD / Domain Model



Hình 3. Sơ đồ ERD / Mô hình miền dữ liệu (14 bảng, PK/FK, cardinality)

Các quan hệ chính: users 1—1 profiles; users 1—n posts; posts 1—n comments; comments 1—n comments (tự tham chiếu, ≤3 cấp); posts 1—n media_attachments; reactions gắn đa hình tới posts/comments qua (target_type, target_id); friendships nối 2 users (user_min, user_max); conversations 1—n messages; notifications n—1 users; reports n—1 users.

5.5 Logical data model — biểu mẫu bảng/entity

ENT-01 · users

Column	Type	Null?	Constraint / Rule	Meaning	Data class
id	uuid	No	PK (uuid v7)	Định danh người dùng	Internal
email	citext	No	UQ; format email	Đăng nhập	PII
username	varchar(30)	No	UQ; [a-z0-9_.]	Tên đăng nhập	Public
password_hash	varchar(72)	No	BCrypt cost 12	Không trả ra API	Secret
display_name	varchar(50)	No	1–50 ký tự	Tên hiển thị	Public
role_id	smallint	No	FK roles RESTRICT	1=User 2=Mod 3=Admin	Internal
status	varchar(20)	No	CK (pending, active, suspended, deactivated, anonymized)	Trạng thái tài khoản	Internal
failed_login_count	smallint	No	≥ 0	Phục vụ FR-003	Internal

Column	Type	Null?	Constraint / Rule	Meaning	Data class
locked_until	timestampz	Yes	—	Khóa tạm thời	Internal
created_at/updated_at	timestampz	No	now()	Audit chuẩn	Internal

ENT-02 · posts

Column	Type	Null?	Constraint / Rule	Meaning	Data class
id	uuid	No	PK (uuid v7 — tối ưu sắp xếp feed)	Định danh bài	Public
author_id	uuid	No	FK users	Tác giả	Internal
content	text	Yes	CK ≤ 5000 ; NOT NULL nếu không có ảnh (BR-01)	Nội dung	User content
privacy	varchar(10)	No	CK (public, friends, private) — BR-02	Quyền riêng tư	Internal
status	varchar(10)	No	CK (published, hidden, deleted) — BR-07	Trạng thái	Internal
comment_count	int	No	≥ 0	Bộ đếm phi chuẩn hóa	Public
reaction_counts	jsonb	No	default ‘{ }’	{“like”:10,...}	Public
created_at	timestampz	No	now()	Khóa sắp xếp feed	Public

ENT-01a · profiles

Column	Type	Null?	Constraint / Rule	Meaning	Data class
user_id	uuid	No	PK, FK users (cascade)	1—1 với users	Internal
avatar_url	text	Yes	—	Ảnh đại diện (trên R2)	Public

Column	Type	Null?	Constraint / Rule	Meaning	Data class
cover_url	text	Yes	—	Ảnh bìa	Public
bio	varchar(300)	Yes	—	Tiểu sử	Public
birthday	date	Yes	hiển thị theo cài đặt riêng tư	Ngày sinh	PII
location	varchar(100)	Yes	—	Nơi ở	Public

ENT-04 · friendships

Column	Type	Null?	Constraint / Rule	Meaning	Data class
user_min_id	uuid	No	PK; FK users; CK user_min < user_max (BR-03)	Người nhỏ hơn trong cặp	Internal
user_max_id	uuid	No	PK; FK users	Người lớn hơn trong cặp	Internal
requester_id	uuid	No	FK users	Ai gửi lời mời	Internal
status	varchar(10)	No	CK (pending, accepted)	Trạng thái quan hệ	Internal
created_at	timestampz	No	now()	Thời điểm gửi	Internal
accepted_at	timestampz	Yes	—	Thời điểm chấp nhận	Internal

ENT-03 · comments

Column	Type	Null?	Constraint / Rule	Meaning	Data class
id	uuid	No	PK (uuid v7)	Định danh bình luận	Public
post_id	uuid	No	FK posts (cascade)	Thuộc bài viết	Internal
author_id	uuid	No	FK users	Người bình luận	Internal
parent_id	uuid	Yes	FK comments; CK ≤ 3 cấp	Trả lời (null = gốc)	Internal

Column	Type	Null?	Constraint / Rule	Meaning	Data class
			(BR-08)		
content	varchar(1000)	No	1–1000 ký tự	Nội dung	User content
status	varchar(10)	No	CK (visible, deleted)	Xóa → “Bình luận đã bị xóa”	Internal
created_at	timestampz	No	now()	Thời điểm	Public

ENT-05 · reactions

Column	Type	Null?	Constraint / Rule	Meaning	Data class
user_id	uuid	No	PK; FK users	Người thả cảm xúc	Internal
target_type	varchar(10)	No	PK; CK (post, comment)	Loại đối tượng	Internal
target_id	uuid	No	PK	Đối tượng (đa hình)	Internal
type	varchar(10)	No	CK (like, love, haha, wow, sad, angry)	Loại cảm xúc (BR-05)	Public
created_at	timestampz	No	now()	Thời điểm	Public

ENT-06 · conversations

Column	Type	Null?	Constraint / Rule	Meaning	Data class
id	uuid	No	PK	Định danh hội thoại	Internal
user_a_id	uuid	No	FK users; UQ(a,b); CK a<b	1 hội thoại/cặp	Internal
user_b_id	uuid	No	FK users	Thành viên còn lại	Internal
last_message_id	uuid	Yes	FK messages	Tin cuối (hiển thị danh sách)	Internal
last_message	timestampz	Yes	—	Khóa sắp xếp	Internal

Column	Type	Null?	Constraint / Rule	Meaning	Data class
_at				hội thoại	
seq_counter	bigint	No	default 0	Cấp seq tăng dần trong hội thoại	Internal

ENT-07 · messages

Column	Type	Null?	Constraint / Rule	Meaning	Data class
id	uuid	No	PK (uuid v7)	Định danh tin	Internal
conversation_id	uuid	No	FK; UQ(conv, seq)	Thuộc hội thoại	Internal
sender_id	uuid	No	FK users	Người gửi	Internal
seq	bigint	No	UQ(conv, seq)	Thứ tự trong hội thoại	Internal
content	varchar(2000)	No	1–2000 ký tự	Nội dung	User content
status	varchar(10)	No	CK (sent, delivered, seen)	Trạng thái	Internal
client_msg_id	uuid	No	UQ(conv, client_msg_id)	Khử trùng (idempotency)	Internal
created_at	timestampz	No	now()	Thời điểm	Internal

ENT-12 · reports

Column	Type	Null?	Constraint / Rule	Meaning	Data class
id	uuid	No	PK	Định danh báo cáo	Internal
reporter_id	uuid	No	FK users	Người báo cáo	Internal
target_type	varchar(10)	No	CK (post, comment, user)	Loại đối tượng	Internal
target_id	uuid	No	—	Đối tượng bị báo cáo	Internal

Column	Type	Null?	Constraint / Rule	Meaning	Data class
reason_code	varchar(20)	No	CK (spam, harassment, nudity, violence, other)	Lý do chuẩn hóa	Internal
detail	varchar(500)	Yes	—	Mô tả thêm	User content
status	varchar(10)	No	CK (open, resolved, dismissed)	Vòng đời một chiều	Internal
resolver_id	uuid	Yes	FK users	Moderator xử lý	Internal
resolved_at	timestampz	Yes	—	Thời điểm xử lý	Internal

ENT-13 · audit_logs (append-only)

Column	Type	Null?	Constraint / Rule	Meaning	Data class
id	bigserial	No	PK; không UPDATE/DELETE	Định danh	Internal
actor_id	uuid	No	FK users	Ai thao tác	Internal
action	varchar(50)	No	—	Hành động (vd post.hide)	Internal
target_type	varchar(20)	Yes	—	Loại đối tượng	Internal
target_id	uuid	Yes	—	Đối tượng	Internal
metadata	jsonb	Yes	—	Chi tiết thao tác	Internal
ip	inet	Yes	—	Địa chỉ IP	Internal
created_at	timestampz	No	now()	Thời điểm	Internal

ENT-10a · permissions và **ENT-10b · role_permissions** (chỗ dựa dữ liệu của ma trận 6.7.2)

Column	Type	Null?	Constraint / Rule	Meaning
permissions.permission_id	smallint	No	PK	Định danh quyền
permissions.code	varchar(40)	No	UQ; dạng resource.action	vd post.hide, report.resolve

Column	Type	Null?	Constraint / Rule	Meaning
permissions.description	varchar(120)	Yes	—	Mô tả
role_permissions.role_id	smallint	No	PK; FK roles	Vai trò
role_permissions.permission_id	smallint	No	PK; FK permissions	Mỗi dòng = một ô ✓ trong ma trận 6.7.2

Các bảng phụ (tóm tắt ràng buộc quan trọng)

Bảng	Ràng buộc quan trọng
follows	PK(follower_id, followee_id); CK follower<>followee
media_attachments	id PK; owner_type(post/message), owner_id; storage_key (R2); CK size_bytes ≤ 10485760; job dọn bản ghi mờ côi
notifications	id PK; recipient_id FK; UQ(recipient, group_key) — gộp (FR-018); is_read
refresh_tokens	id PK; user_id FK; token_hash (băm); expires_at; revoked_at; replaced_by_id — xoay vòng (NFR-SEC-03)
roles	role_id PK; name (User/Moderator/Admin); seed cố định

5.6 Index, query và dung lượng

Query / Use Case	Filter / Sort	Volume	Index / Partition	Trade-off / Evidence
UC-08 News Feed	author_id IN (bạn bè+theo dõi), status='published', BR-02, ORDER created_at DESC	500k đọc/ngày	idx(author_id, created_at DESC) WHERE published	Cache Redis 30s trang đầu; explain plan Index Scan
UC-09 Trang cá nhân	author_id = :id, created_at DESC	100k/ngày	Dùng chung idx trên	—
UC-15 Tải hội thoại	conversation_id, seq DESC LIMIT 20	300k/ngày	idx(conversation_id, seq DESC)	Cursor theo seq, không OFFSET

Query / Use Case	Filter / Sort	Volume	Index / Partition	Trade-off / Evidence
UC-16 Tìm người dùng	display_name khớp tiền tố không dấu	20k/ngày	GIN pg_trgm trên unaccent(display_name)	Index lớn (~15%), chấp nhận ở MVP
UC-17 Thông báo	recipient_id, updated_at DESC	200k/ngày	Partial index WHERE is_read=false	Nhỏ, phục vụ badge
Kiểm tra quan hệ	friendships theo cặp	Rất cao	PK cặp + cache Redis TTL 60s	Chấp nhận trễ 60s khi hủy kết bạn

Dung lượng năm 1 (ước lượng): users 10k; posts 1,8M; messages 18M; notifications 30M.
Chưa cần partition; messages sẽ partition theo tháng khi > 50M hàng.

5.7 Data lifecycle, migration và quality

Chủ đề	Quyết định / Quy tắc	Verification
Seed / reference data	roles, reason_code seed bằng EF Core migration, idempotent; admin đầu tiên tạo qua biến môi trường	Review migration
Migration / rollback	EF Core Migrations, versioned, chạy trên CI; backward-compatible 1 phiên bản (expand–contract)	CI check
Backup / restore	pg_basebackup hằng ngày + WAL archiving (RPO ≤ 15 phút); restore drill	Restore drill log
Retention / deletion	Post/Comment soft-delete 90 ngày rồi xóa cứng; tài khoản Deactivated ẩn danh PII sau 30 ngày; audit_logs giữ 12 tháng	Job log + inspection
Data quality	CHECK/UNIQUE/FK là tuyến phòng thủ cuối; job đếm đối soát bộ đếm với bản ghi thật	Job report
Audit / lineage	Mọi thao tác Mod/Admin ghi audit_logs (ai, hành động, đối tượng, IP, thời điểm); append-only	Query kiểm tra

6. System Design

Mô tả cấu trúc, tương tác, triển khai và các quyết định giúp hệ thống đáp ứng FR/NFR, trong khuôn khổ ràng buộc: ASP.NET Core, PostgreSQL, JWT, RBAC, REST API.

6.1 Architecture drivers và constraints

Driver ID	Driver / Constraint	Source	Design impact	Evidence
DRV-01	Backend ASP.NET Core (.NET 8), DB PostgreSQL	Ràng buộc đề bài	Modular monolith; EF Core + Npgsql; SignalR	ADR-001
DRV-02	Xác thực JWT, phân quyền RBAC	Ràng buộc; NFR-SEC-02/03	Access token ngắn + refresh rotation; policy-based + ownership	ADR-002
DRV-03	Nhắn tin, thông báo realtime ≤ 1s	GOAL-02; NFR-PERF-03	SignalR Hub + Redis backplane khi scale	ADR-003
DRV-04	Feed p95 ≤ 500ms @ 1.000 CCU	GOAL-01; NFR-PERF-01	Fan-out-on-read + index + Redis cache	ADR-004; k6
DRV-05	Đội 3 người, ~25 ngày, phục vụ học tập	Phạm vi 1.3	Modular monolith thay microservices; hạ tầng tối giản 1 VPS	ADR-001
DRV-06	Bảo vệ dữ liệu cá nhân (NĐ 13/2023)	NFR-COMP-01	Ẩn danh PII, audit log, quyền xóa tài khoản từ đầu	Inspection

6.2 System Context Diagram

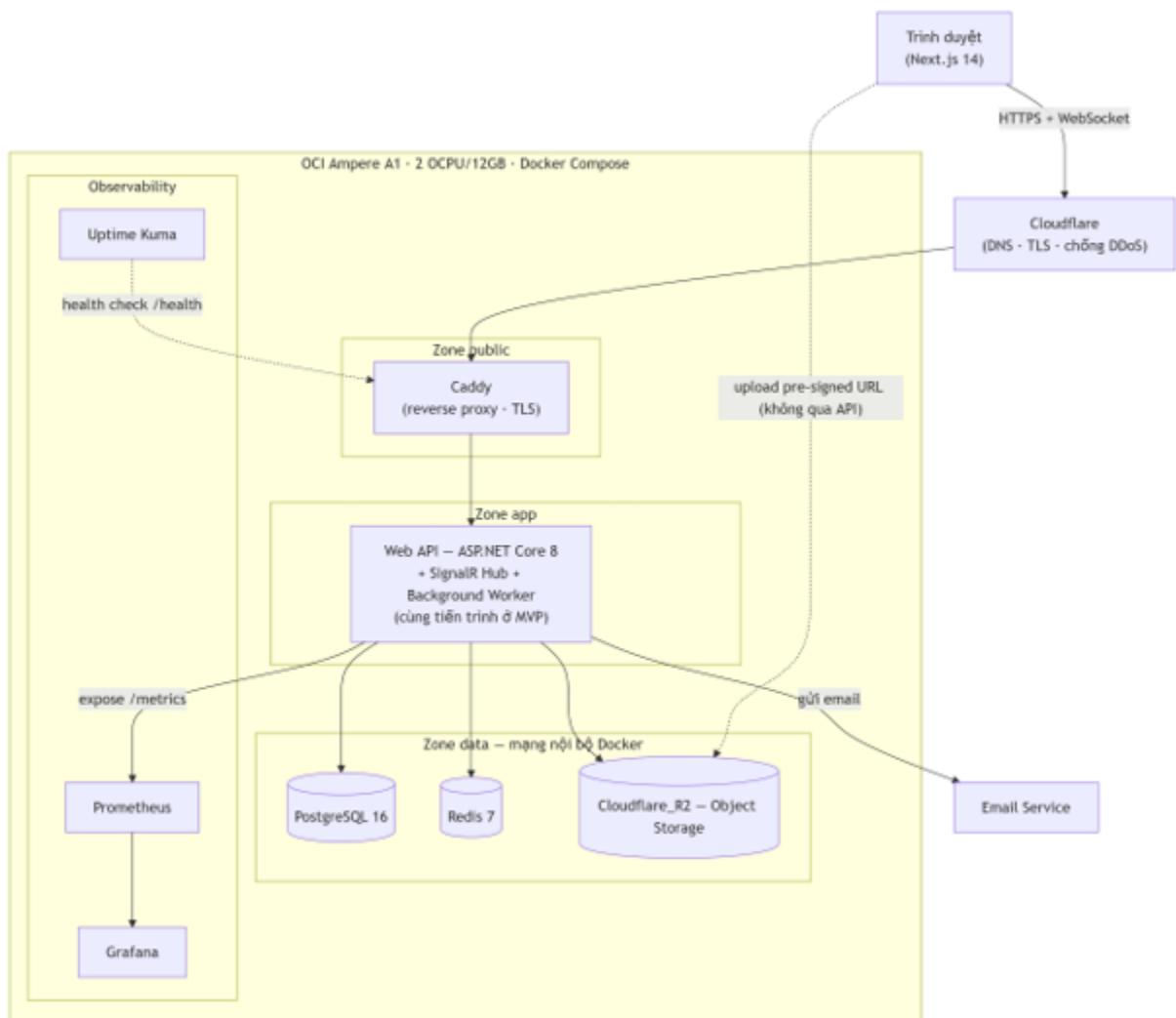


Hình 4. Sơ đồ ngữ cảnh hệ thống (System Context)

External actor/system	Purpose	Data exchanged	Trust boundary
Người dùng (trình	Dùng toàn bộ chức	HTTPS: JSON API +	External / End user

External actor/system	Purpose	Data exchanged	Trust boundary
duyet)	năng qua web app	WebSocket; JWT header	
Email Service (SMTP/API)	Gửi email xác minh, đặt lại mật khẩu	Địa chỉ email, link token dùng một lần	External / DevOps
Object Storage (S3/R2)	Lưu & phục vụ ảnh	File ảnh; pre-signed URL hạn 10 phút	External / DevOps

6.3 Container / Deployment-unit view

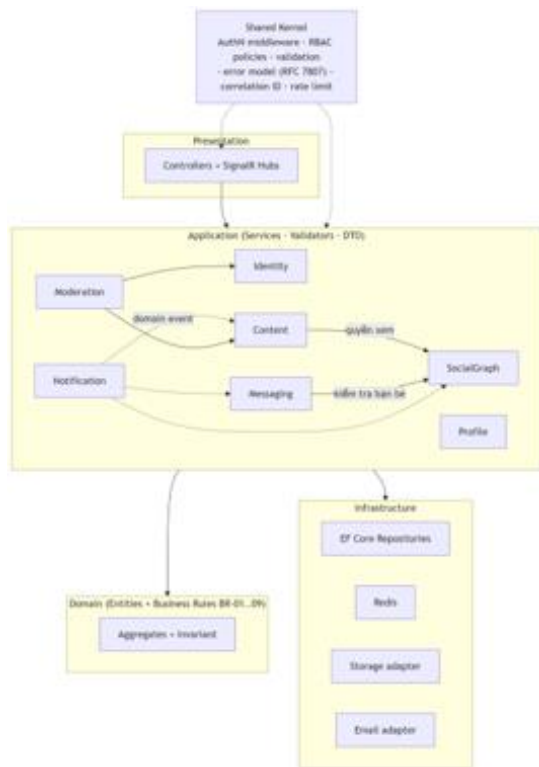


Hình 5. Sơ đồ Container / Triển khai (Browser → Cloudflare → Caddy → Web API → PostgreSQL/Redis/R2; zone public/app/data)

ID	Container	Trách nhiệm	Công nghệ	Scale / HA
CNT-01	Web Frontend	Giao diện, render feed/hồ sơ/chat	Next.js 14	Scale ngang sau CDN
CNT-02	Web API	Toàn bộ nghiệp	ASP.NET Core	Stateless, ≥ 2

ID	Container	Trách nhiệm	Công nghệ	Scale / HA
		vụ; REST /api/v1	8, EF Core	instance
CNT-03	Realtime Hub	Đẩy tin, đã xem, thông báo	SignalR (cùng CNT-02 ở MVP)	Redis backplane khi ≥ 2 instance
CNT-04	Background Worker	Email, dọn media mờ côi, đối soát bộ đếm	IHostedService	Leader-election qua khóa DB
CNT-05	PostgreSQL	Nguồn sự thật dữ liệu nghiệp vụ	PostgreSQL 16	1 primary; WAL archiving
CNT-06	Redis	Cache, backplane, presence, rate limit	Redis 7	Mất Redis vẫn chạy (degrade)
CNT-07	Object Storage	Ảnh bài viết/avatar; upload/serve trực tiếp qua pre-signed URL (không qua Web API)	Cloudflare R2 (S3-compatible)	Managed; egress miễn phí; backup

6.4 Component / Module view

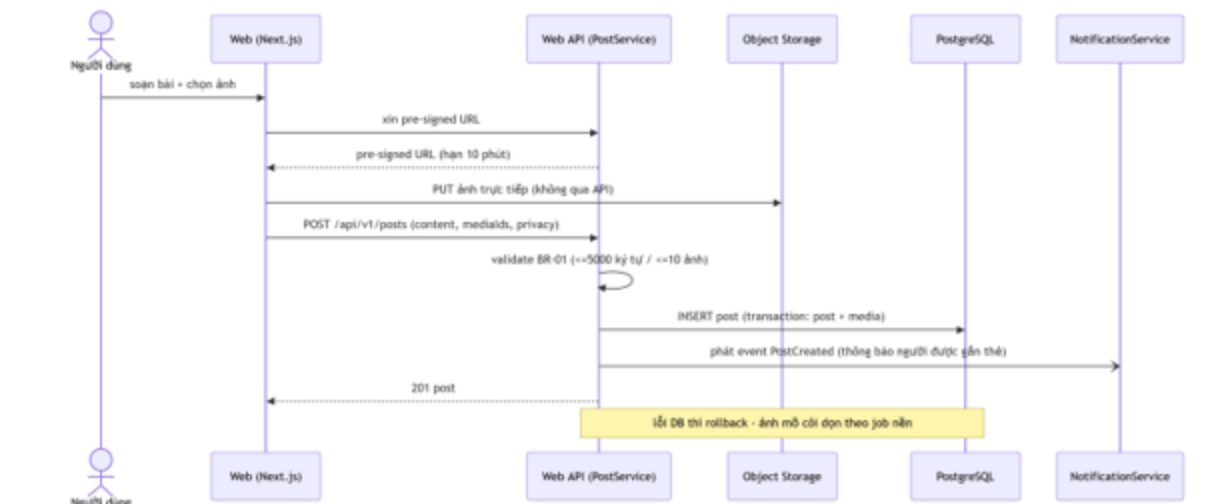


Hình 6. Sơ đồ Component / Module (phân tầng; 7 module + Shared Kernel)

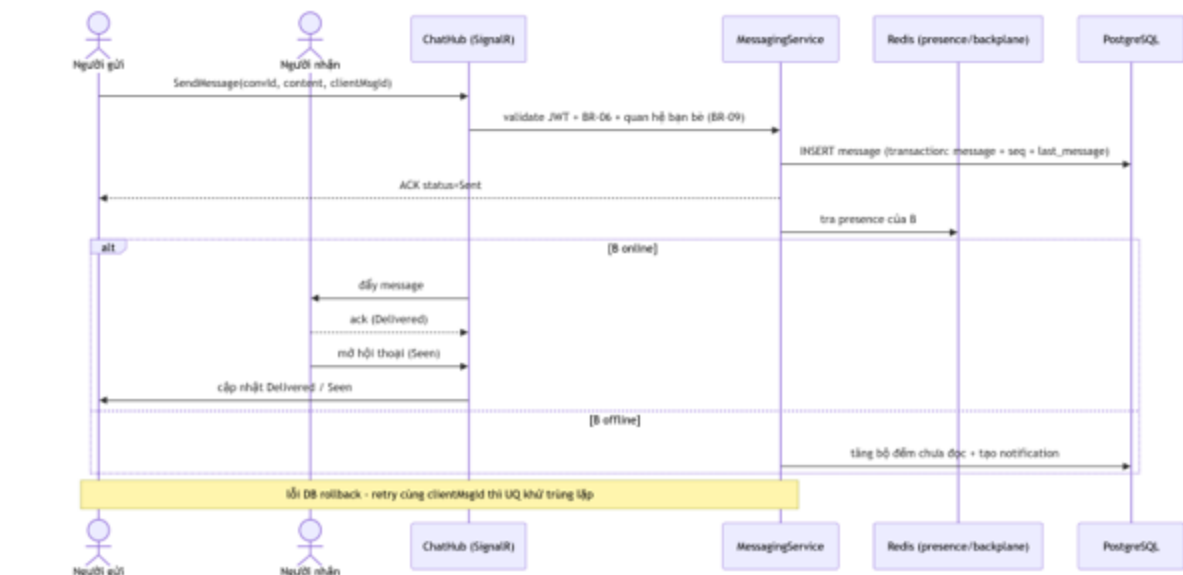
ID	Component	Provides	Depends on	Related FR/NFR
CMP-01	Identity	/api/v1/auth/*	PostgreSQL, Email, Redis	FR-001–003; NFR-SEC-01–03
CMP-02	Profile	/api/v1/users/*	Storage, Identity	FR-013; UC-03
CMP-03	SocialGraph	/api/v1/friends/, /follows/	PostgreSQL, Redis, Notification	FR-010–013; BR-03
CMP-04	Content	/api/v1/posts/*, /feed	SocialGraph, Storage, Redis	FR-004–009; NFR-PERF-01/02
CMP-05	Messaging	/api/v1/conversations/*; ChatHub	SocialGraph, Redis	FR-015/016; NFR-PERF-03
CMP-06	Notification	/api/v1/notifications/*; Hub	PostgreSQL, Redis, SignalR	FR-018
CMP-07	Moderation	/api/v1/reports/, /admin/	Content, Identity, AuditLog	FR-019/020; BR-07
CMP-08	Shared Kernel	AuthN	Redis	NFR-SEC-

ID	Component	Provides	Depends on	Related FR/NFR
		middleware, RBAC policy, error model, correlation ID, rate limit		02/04; NFR- OBS-01

6.5 Sequence / Interaction Design



Hình 7. SEQ-01 · Đăng bài (pre-signed upload → transaction → event)

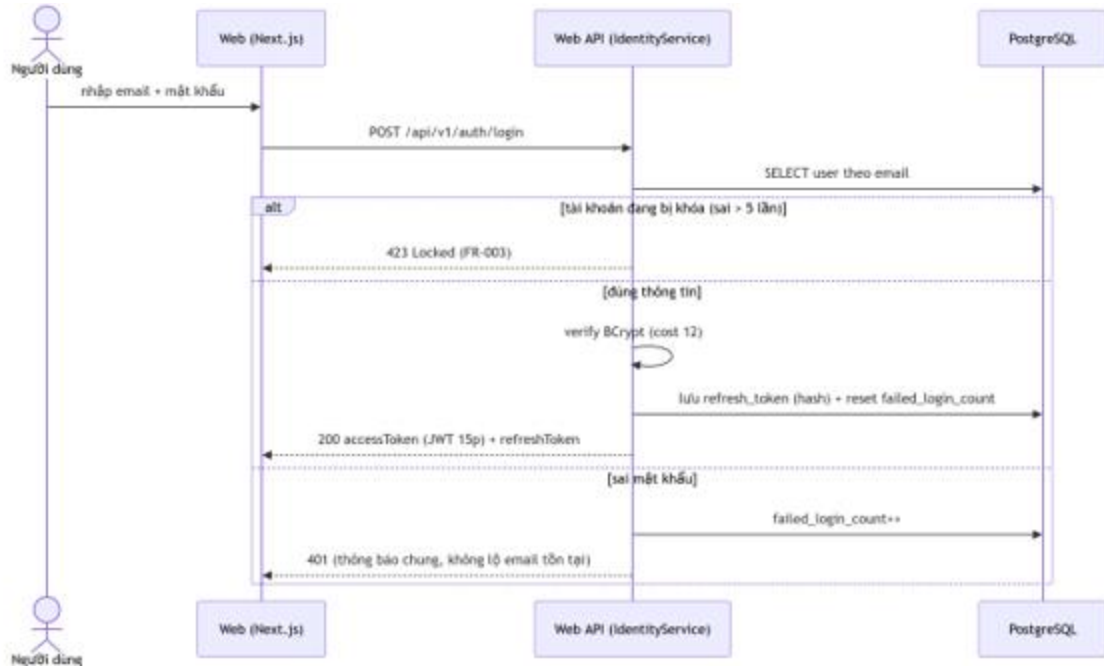


Hình 8. SEQ-02 · Nhắn tin realtime (Sent → Delivered → Seen)

Hình 9 — SEQ-03 · Xem News Feed

(PLACEHOLDER — render từ Nhom5_SoDo_v1.md, mục SEQ-03, rồi thay file seq-feed.png)

Hình 9. SEQ-03 · Xem News Feed (cache hit/miss · degrade Redis · 503 timeout)



Hình 10. SEQ-04 · Đăng nhập + cấp JWT (lockout · lỗi chung)

Flow ID	Trigger	Happy path	Failure handling	Related
SEQ-01	Đăng bài	Upload pre-signed → tạo post transaction → event PostCreated	Rollback khi DB lỗi; media mờ côi dọn theo job	UC-04; FR-004
SEQ-02	Gửi tin nhắn	Ghi DB → ACK Sent → đẩy B → Delivered/Seen; $p95 \leq 1s$	Retry idempotent qua clientMsgId; B offline → badge	UC-15; FR-015/016
SEQ-03	Mở News Feed	Cache hit trang đầu (30s) hoặc query index; 20 bài + cursor	Redis chết → đọc DB; DB timeout → 503	UC-08; FR-009
SEQ-04	Đăng nhập	Verify BCrypt	Sai 5 lần →	UC-02; FR-

Flow ID	Trigger	Happy path	Failure handling	Related
		→ phát access + refresh token	lockout; lỗi chung không lộ email	002/003

6.6 API / Interface Contract

Chuẩn chung: REST JSON, tiền tố /api/v1; xác thực Bearer JWT; OpenAPI (Swashbuckle); Postman collection theo môi trường.

API ID	Method / Endpoint	AuthZ	Responses / Errors	SLA / Idemp.
API-Auth-Register	POST /auth/register	Anonymous	201; 400; 409 trùng	—
API-Auth-Login	POST /auth/login	Anonymous	200 {access, refresh}; 401; 423 locked	p95 ≤ 300ms
API-Auth-Refresh	POST /auth/refresh	Refresh token	200 token mới; 401 thu hồi/hết hạn	Rotate an toàn
API-Post-Create	POST /posts	Role User; tự thân	201; 400 BR-01; 401	p95 ≤ 800ms
API-Post-Update	PATCH/DELETE /posts/{id}	Owner hoặc Moderator(hide)	200; 403; 404	DELETE idempotent
API-Feed	GET /feed?cursor=&limit=	Role User	200 {items, nextCursor}; 400	p95 ≤ 500ms
API-Comment	POST /posts/{id}/comments	User có quyền xem bài	201; 403 BR-02; 400 BR-08	—
API-Reaction	PUT /{targetType}/{id}/reactions	User có quyền xem	200 counts; 403	PUT idempotent (BR-05)
API-Friend-Request	POST /friends/requests	Role User	201; 409; 400 tự gửi	Idempotent theo cặp
API-Friend-Respond	POST /friends/requests/{id}/accept decline	Người nhận	200; 403; 404	Idempotent
API-Message-Send	POST /conversations/{id}/messages	Thành viên (BR-06)	201; 403; 409 trùng clientMsgId	Idempotency-Key

API ID	Method / Endpoint	AuthZ	Responses / Errors	SLA / Idemp.
API-Search	GET /search?q=&type =	Role User	200; 400 ($q \geq 2$ ký tự)	$p95 \leq 700ms$
API-Admin-Users	GET/PATCH /admin/users/{id}	Role Admin	200 + audit; 403	PATCH idempotent
API-Reports	POST /reports; PATCH /reports/{id}	User gửi; Moderator xử lý	201/200; 403	—

Chuẩn hợp đồng: version trong URL (/api/v1); lỗi RFC 7807 Problem Details {type, title, status, errors, traceId}; keyset/cursor pagination (limit 20, tối đa 50); rate limit 100 req/phút/user, 10 req/phút cho auth; optimistic concurrency (xmin qua EF Core).

6.7 Security & Privacy Design

6.7.1 Ba tầng kiểm soát truy cập

RBAC một mình không đủ bảo vệ tài nguyên thuộc sở hữu người dùng; mỗi yêu cầu đi qua ba chốt:

Tầng	Câu hỏi cần trả lời	Cách kiểm tra
1. Xác thực (AuthN)	Người gọi là ai?	Xác minh chữ ký JWT — không truy vấn DB
2. Phân quyền vai trò (RBAC)	Vai trò này được làm loại hành động này không?	Policy/Claims ASP.NET Core, dựa trên role trong token
3. Quyền trên tài nguyên	Người này được thao tác trên đúng tài nguyên NÀY không?	Kiểm tra ownership/quan hệ bạn bè ở tầng nghiệp vụ, có truy vấn dữ liệu thật

Bỏ sót tầng 3 là lỗ hổng IDOR — nhóm lỗi phổ biến nhất với loại ứng dụng này.

6.7.2 Ma trận Role–Permission (resource.action)

Nguyên tắc: **backend mặc định từ chối (default deny), least privilege**. ✓(own) = chỉ trên tài nguyên của mình; ✓(bạn) = chỉ khi là bạn bè.

Permission (resource.action)	Guest	User	Moderator	Admin
post.read.public	✓	✓	✓	✓
post.read.friends	—	✓(bạn)	✓	✓
post.create	—	✓	✓	✓
post.update / post.delete	—	✓(own)	—	✓

Permission (resource.action)	Guest	User	Moderator	Admin
post.hide (BR-07)	—	—	✓	✓
comment.create	—	✓	✓	✓
reaction.set	—	✓	✓	✓
friend.request / friend.respond	—	✓	✓	✓
message.send	—	✓(bạn)	✓(bạn)	✓(bạn)
report.create	—	✓	✓	✓
report.resolve	—	—	✓	✓
user.lock / user.unlock	—	—	—	✓
role.assign	—	—	—	✓
audit.read	—	—	—	✓

RBAC dữ liệu hóa (chỗ dựa dữ liệu của ma trận). Ma trận trên **không hard-code trong mã** mà được seed vào hai bảng: `permissions(permission_id, code 'resource.action', description)` và `role_permissions(role_id, permission_id)` — mỗi ô ✓ là một dòng `role_permissions` (xem ENT-10a/10b, từ điển cột ở Mục 5.5). Backend nạp quyền của vai trò từ DB (có cache, nạp lại khi đổi) và áp **default deny**; các điều kiện own/bạn được kiểm ở tầng nghiệp vụ (tầng 3, mục 6.7.1).

Trả lời câu hỏi phản biện (“*thêm vai trò chỉ có `report.resolve` mà không `post.hide` thì phải sửa gì?*”): chỉ cần **INSERT** 1 dòng `roles` (vai trò mới) + các dòng `role_permissions` tương ứng (`report.resolve` = có, `post.hide` = không) rồi gán `users.role_id`; **không sửa mã nghiệp vụ hay policy** vì policy đọc quyền từ DB. Ở MVP nhóm seed sẵn 3 vai trò (User/Moderator/Admin) cho đơn giản, nhưng thiết kế đã tách `resource.action` nên nâng cấp là thay dữ liệu, không thay code.

6.7.3 JWT flow và claims

Access token (JWT, HS256 ở MVP) chứa các claim tối thiểu:

Claim	Ý nghĩa
sub	user_id (định danh chủ thể)
role	vai trò RBAC (User/Moderator/Admin)
iat / exp	phát hành / hết hạn (TTL 15 phút)
jti	id token — phục vụ thu hồi/kiểm tra reuse

Luồng: đăng nhập → cấp access (15 phút) + refresh token (lưu bấm trong DB); khi hết hạn → POST `/auth/refresh` xoay vòng token, phát hiện dùng lại (reuse) thì thu hồi cả chuỗi; đổi mật khẩu/đăng xuất thu hồi toàn bộ phiên. (Sơ đồ: `Nhom4_SoDo_v1.md` mục 7.4.)

6.7.4 Threat model (có risk rating) và mitigation

Asset / Threat	Likelihood	Impact	Risk	Control (Prevent/Detect/Respond)	Test
Mật khẩu / credential stuffing	Medium	High	High	BCrypt 12; lockout 5 lần/15 phút; rate limit auth	Unit test + ZAP
JWT / token bị đánh cắp	Low	High	Medium	Access 15 phút; refresh rotation + reuse detection; log bất thường	AuthZ test + review
Vượt quyền ngang (IDOR)	High	High	Critical	Resource-based authz kiểm tra ownership/membership ở tầng Application	AuthZ test ma trận (chạy CI)
SQL Injection / XSS	Medium	High	High	EF parameterize d; encode output; CSP; re-encode ảnh	ZAP + kiểm thử thủ công
PII rò rỉ (email, ngày sinh)	Low	High	Medium	TLS 1.2+; ẩn danh hóa sau xóa; quy trình xử lý sự cố	Inspection theo NĐ 13
Nội dung độc hại / spam	High	Medium	High	Rate limit đăng bài/bình luận; hàng đợi báo cáo + kiểm duyệt	Role-based test

6.7.5 Test 401/403/truy cập chéo (negative authorization)

TC	Kịch bản	Kỳ vọng
TC-A01	Gọi API bảo vệ không kèm JWT	401

TC	Kịch bản	Kỳ vọng
TC-A02	JWT hết hạn / chữ ký sai	401
TC-A03	User A gọi PATCH /posts/{id của B} (đổi ID trên URL)	403 (IDOR)
TC-A04	Đọc /conversations/{id} khi không phải thành viên	403 (IDOR)
TC-A05	User thường gọi /admin/*	403
TC-A06	User thường gọi endpoint kiểm duyệt (PATCH /reports/{id})	403
TC-A07	Gửi tin cho người không phải bạn bè (BR-09)	403

6.8 Deployment, configuration và operations

Env.	Topology	Configuration / Secrets	Deployment	Rollback
Dev	Docker Compose máy dev: API + PostgreSQL + Redis + Mailpit; ảnh trên Cloudflare R2 (bucket -dev)	appsettings.Dev elopment + .env local	Chạy local; hot reload	—
Staging	1 VPS Docker Compose, cấu hình thu nhỏ	Biến môi trường từ CI variables	CI/CD build → test → deploy nhánh develop	Redeploy image trước theo tag
Production	OCI VPS: Caddy (TLS) → 2 API container → PostgreSQL, Redis; ảnh trên Cloudflare R2	Secret trong CI protected variables; không secret trong image	Deploy theo tag; rolling từng container sau health check	Rollback image tag; migration expand–contract

Sơ đồ triển khai (network zones, backup, observability) đã thể hiện ở **Hình 5** (Mục 6.3 · Container / Triển khai).

6.9 Observability và resilience

Concern	Signal / Mechanism	Threshold / Policy
Health	/health/live và /health/ready (DB, Redis); Caddy loại instance fail	Fail 3 lần → loại ≤ 30s

Concern	Signal / Mechanism	Threshold / Policy
Logs	Serilog structured JSON; correlation ID xuyên request→hub→worker; redact PII	Retention 30 ngày
Metrics	Prometheus: RED theo endpoint + business metrics (bài/phút, tin/phút)	Alert error rate > 1%/5 phút
Timeout / retry	HTTP + DB timeout 5s; Polly retry + jitter cho call ngoài; circuit breaker cho Redis	Không retry ghi không idempotent
Backup / DR	pg_basebackup + WAL liên tục; restore drill	RPO ≤ 15 phút; RTO ≤ 2 giờ

Phạm vi cam kết MVP (đã triển khai): /health, Serilog, Uptime Kuma, backup + 1 lần restore drill, Prometheus + Grafana, k6 load test feed, ArchUnitNET. Roadmap (thiết kế, chưa triển khai trong kỳ): Loki, Tempo/OpenTelemetry, ≥2 instance + chaos drill, restore drill hằng quý.

6.10 Architecture Decision Records (ADR)

ADR	Quyết định	Options đã cân nhắc	Rationale (tóm tắt)	Hệ quả (lợi ích / chi phí, rủi ro)	Review khi
ADR-001	Modular monolith trên ASP.NET Core	A. Microservice s; B. Monolith phân lớp; C. Modular monolith	A vượt năng lực đội 3 người/25 ngày; C giữ chi phí vận hành thấp, ranh giới module cho phép tách service sau	Lợi: deploy 1 đơn vị, gỡ lỗi đơn giản. Chi phí/rủi ro: phải kỷ luật ranh giới module (ArchUnitNET chặn tham chiếu chéo); scale theo cả khối	CCU > 5.000 hoặc đội > 10 người
ADR-002	JWT 15 phút + refresh rotation	A. JWT dài hạn; B. Session server; C. JWT ngắn + refresh xoay vòng	A không thu hồi được; B mất stateless; C giới hạn cửa sổ tấn công 15 phút, vẫn stateless	Lợi: thu hồi được khi lộ/đổi mật khẩu, API stateless. Chi phí: thêm bảng refresh_tokens + endpoint refresh; client phải tự làm	Chuyển RS256 đa dịch vụ

ADR	Quyết định	Options đã cân nhắc	Rationale (tóm tắt)	Hệ quả (lợi ích / chi phí, rủi ro)	Review khi
				mới token	
ADR-003	SignalR + Redis backplane	A. Polling 3s; B. SSE; C. SignalR WebSocket	A trễ ~1,5s không đạt NFR; B một chiều; C hai chiều, tích hợp sẵn ASP.NET Core	Lợi: realtime hai chiều đạt $\leq 1s$, tận dụng hệ sinh thái .NET. Chi phí/rủi ro: phụ thuộc Redis backplane khi scale; cần sticky session/skip-negotiation	Cần mobile push
ADR-004	Feed fan-out-on-read	A. Fan-out-on-write; B. Fan-out-on-read + cache	A phức tạp khi sửa/xóa bài & đổi quyền; B đơn giản, đúng BR-02 tại thời điểm đọc, đạt ngưỡng với index + cache	Lợi: đơn giản, đúng quyền tức thời, ghi rẻ. Chi phí/rủi ro: feed là điểm nóng đọc; khi bạn-bè-trung-bình/CCU tăng phải chuyển hybrid	p95 vượt 400ms ở tải thường

7. Ma trận truy vết và kế hoạch kiểm chứng

7.1 Requirements Traceability Matrix (RTM)

Goal	UC	US / AC	FR	NFR	Data	Design / API	Test
GOAL-01	UC-08	US-008/AC-01	FR-009	NFR-PERF-01	ENT-02	CMP-04 / API-Feed	US-008/AC-04 (k6)
GOAL-02	UC-15	US-015/AC-01	FR-015	NFR-PERF-03	ENT-06, ENT-07	CMP-05 / API-Message-Send	US-015/AC-01 (E2E)
GOAL-03	UC-04	US-004/AC-	FR-006	NFR-SEC-02	ENT-02	CMP-04 / API-Post-	TC-A03 (IDOR)

Goal	UC	US / AC	FR	NFR	Data	Design / API	Test
		04				Update	
GOAL-03	UC-15	US-015/AC-04	FR-016	NFR-SEC-02	ENT-06	CMP-05 / API-Message-Send	TC-A04, TC-A07
GOAL-03	UC-10	US-010/AC-04	FR-011	NFR-SEC-02	ENT-04	CMP-03 / API-Friend-Respond	US-010/AC-04
GOAL-04	UC-02	US-002/AC-03	FR-003	NFR-REL-01	ENT-01	CMP-01 / API-Auth-Login	US-002/AC-03 (lockout)
GOAL-05	UC-03	US-003	FR-005	NFR-COMP-01	ENT-01	CMP-02 / API-Admin-Users	NFR-COMP-01 (inspection)

Truy vết **hai chiều**: đọc **xuôi** (Goal → UC → US/AC → FR/NFR → ENT → API/CMP → Test) để kiểm mỗi mục tiêu đều có đường hiện thực và kiểm chứng; đọc **ngược** (Test/Thiết kế → yêu cầu) để phát hiện artefact “mò côi” — thiết kế/test không phục vụ yêu cầu nào, hoặc FR/NFR không được test nào phủ. RTM trên phủ các luồng ưu tiên (Must); các FR/NFR còn lại truy vết qua cột “Related” trong mỗi Use Case và mục 7.2.

7.2 Verification Plan

Item ID	Verification method	Environment / Data	Expected evidence
NFR-PERF-01	Load test (k6)	Staging, dữ liệu seed; k6 từ máy riêng	Báo cáo p95 ≤ 500ms + Grafana
NFR-PERF-03	Test (E2E)	2 trình duyệt, staging	Đo p95 gửi→nhận ≤ 1s
NFR-SEC-02	Test (AuthZ tự động)	CI, ma trận quyền	TC-A01..A07 đều đạt mã lỗi kỳ vọng
NFR-REL-02	Demonstration (restore drill)	Staging	Nhật ký cronjob + biên bản khôi phục
BR-02	Test (integration)	Ma trận quyền xem	Bài “Bạn bè” không lộ cho người lạ
FR-004..020	Test (API/Postman + newman)	Dev/staging	Bộ test xanh trên CI

7.3 Open Issues, assumptions và risks

ID	Type	Description	Impact	Resolution / ADR
ISS-01	Risk	SignalR realtime tốn thời gian hơn dự kiến	High	Fallback polling 3s; giữ hợp đồng API (mục 7.7 v0.2)
ISS-02	Risk	Tích hợp Cloudflare R2 (CORS, pre-signed URL) trực trực	Medium	Cấu hình CORS cho bucket; nếu vẫn vướng thì tạm lưu volume VPS, giữ nguyên bảng metadata để chuyển lại R2
ISS-03	Assumption	Email miễn phí đủ cho quy mô demo	Low	Bật tự xác minh cho môi trường demo nếu cần
ISS-04	Risk	Dò quét/spam đăng ký sau khi mở Internet	Medium	Rate limit + lockout + firewall chỉ mở 80/443

8. Review Gate và phê duyệt

8.1 Checklist phân tích

- ☐ Phạm vi, actor và thuật ngữ không mâu thuẫn
- ☐ Mỗi Use Case (lỗi) có trigger, precondition, main flow, alternative/exception và guarantee
- ☐ User Story thể hiện giá trị; Acceptance Criteria quan sát và kiểm thử được
- ☐ Mỗi FR có nguồn, ưu tiên và phương pháp xác minh
- ☐ Mỗi NFR có metric, threshold, environment và scope
- ☐ Không còn từ mơ hồ chưa định lượng (nhanh, dễ dùng, an toàn)

8.2 Checklist dữ liệu

- ☐ Entity và quan hệ dùng đúng ngôn ngữ nghiệp vụ; có owner/source of truth
- ☐ Cardinality, identity, invariants và transaction boundary rõ
- ☐ Schema có datatype, nullability, constraints, audit và delete behavior
- ☐ PII/classification, retention, backup/restore và migration được mô tả
- ☐ Index xuất phát từ query/volume cụ thể và có kế hoạch kiểm chứng

8.3 Checklist thiết kế hệ thống

- ☐ Context/container/component/sequence/deployment nhất quán
- ☐ Mỗi component có trách nhiệm rõ, interface rõ và dependency hợp lý
- ☐ API có validation, error contract, security, versioning và idempotency
- ☐ Thiết kế thể hiện timeout, retry, rollback và degraded behavior

- ☐ Logging, metrics, alerts đủ để vận hành
- ☐ Quyết định quan trọng có ADR, trade-off và tiêu chí xem xét lại

8.4 Sign-off

Vai trò	Họ tên	Kết luận	Ngày
Product Owner / BA	[NHẬP]	Approve / Conditional	[DATE]
Architect / Tech Lead	[NHẬP]	[NHẬP]	[DATE]
Security / Data Owner	[NHẬP]	[NHẬP]	[DATE]
Giảng viên hướng dẫn	[NHẬP]	[NHẬP]	[DATE]

9. Phụ lục

9.1 Changelog

Version	Date	Summary of changes	Review status
0.1	19/08/2026	Bản draft đầu tiên	Draft
0.2	20/08/2026	Bổ sung DB, System Design, ADR	In Review
1.0	23/08/2026	Thu nhỏ UC (6 UC chi tiết), thêm US/AC, ma trận RBAC, RTM, sơ đồ State Machine; sửa nhất quán	Ready
4.0	30/08/2026	Bản nộp: chèn sơ đồ, đổi sang Cloudflare R2 (đạt 76,5/90)	Submitted
5.0	02/09/2026	Sửa theo phiếu chấm: bổ sung đủ Mục 7–9, bảng permissions/role_permissions, từ điển cột đầy đủ, thống nhất mã actor (STK-), vá đứt mã, caption “Hình N.”, SEQ-03, ADR có hệ quả	Ready

9.2 Nguồn và công cụ

- **Nguồn tham khảo:** ràng buộc đề bài; rubric Phân tích & Thiết kế HTTT; OWASP Top 10; Nghị định 13/2023/NĐ-CP.
- **Công cụ:** Postman, DBeaver/DataGrip, draw.io, Figma; Pandoc (sinh tài liệu Word).

- **Công cụ AI:** hỗ trợ soạn thảo, rà soát nhất quán và sinh mã nguồn sơ đồ (Mermaid/PlantUML) — bản vẽ và nội dung do nhóm kiểm tra, chỉnh sửa và chịu trách nhiệm cuối.

9.3 Deliverables index

Artefact	Bắt buộc?	Vị trí
Use Case Diagram & Specifications	Có	Mục 2 + Nhom4_SoDo_v1.md (1)
Backlog + Acceptance Criteria	Có	Mục 3
FR/NFR Catalog	Có	Mục 4
Domain Model / ERD / Data Dictionary	Có	Mục 5 + Nhom4_SoDo_v1.md (5)
Context/Container/Component/Sequence/State/Deployment	Có	Mục 6 + Nhom4_SoDo_v1.md (2–7)
API Contract	Có	Mục 6.6
ADRs	Có	Mục 6.10
Traceability & Verification	Có	Mục 7